GTAG

GUIDE PRATIQUE D'AUDIT DES TECHNOLOGIES DE L'INFORMATION

Audit continu : Répercussions sur l'assurance, le pilotage et l'évaluation des risques

The Institute of Internal Auditors

Guide pratique d'audit des technologies de l'information (GTAG) 3
Audit continu : répercussions sur l'assurance, le pilotage et l'évaluation des risques

Auteur
David Coderre, Gendarmerie royale du Canada (GRC)

Experts
John G. Verver, ACL Services Ltd.
J. Donald Warren Jr., Center for Continuous Auditing, Rutgers University

Octobre 2005

Copyright © 2005, The Institute of Internal Auditors, 247 Maitland Avenue, Altamonte Springs, Florida 32701-4201. Tous droits réservés. Imprimé aux États-Unis d'Amérique. Aucune partie de cette publication ne peut être reproduite, stockée dans un système de recherche ou transmise sous quelque forme que ce soit, ni par aucun moyen (électronique, mécanique, reprographie, enregistrement ou autre), sans l'autorisation écrite préalable de l'éditeur.

L'IIA publie ce document à titre informatif et pédagogique. Cette publication entend donner des informations, mais ne se substitue en aucun cas à un conseil juridique ou comptable. L'IIA ne fournit pas ce type de service, et la publication du présent document ne s'accompagne d'aucune garantie quant aux résultats juridiques ou comptables. En cas de problèmes juridiques ou comptables, il convient de recourir aux services de professionnel.

GTAG — Table des matières

1. Résumé 1
   - Audit continu 1
   - Le besoin d'audit/de pilotage continus : une approche intégrée 1
   - Les rôles de l'audit interne et du management 2
   - Le pouvoir de l'audit continu 2
   - Problèmes de mise en œuvre 2
2. Introduction 3
   - Audit continu : un bref historique 3
   - L'environnement actuel de l'audit 4
   - Référentiel du COSO sur le management des risques de l'entreprise (COSO ERM) 4
   - Les rôles de l'audit interne et du management 5
   - Avantages de l'audit et du pilotage continus 5
3. Principaux termes et concepts : un besoin de clarification 7
   - Le continuum de l'audit continu 8
4. Relation entre audit continu, assurance continue et pilotage continu 10
   - Assurance continue 10
   - Pilotage continu 10
   - Audit continu 11
5. Où s'applique l'audit continu 12
   - Applications de l'évaluation continue des contrôles 12
   - Applications de l'évaluation continue des risques 15
   - Élaboration du plan d'audit 15
   - Soutien aux missions d'audit 17
   - Vérification de la mise en œuvre des recommandations d'audit 17
   - Conclusion 18
6. Mise en place de l'audit continu 19
   - Les objectifs de l'audit continu 19
   - Relation entre évaluation continue des contrôles et des risques 24
   - Gérer et communiquer les résultats 26
   - Obstacles à surmonter et autres considérations 27
7. Conclusion 29
8. Annexe A — Exemple d'audit continu appliqué aux créances fournisseurs 30
9. Annexe B — Normes connexes 33
10. Annexe C — Auto-évaluation en audit continu 34
11. À propos des auteurs/de l'équipe de projet 36
12. Bibliographie 37

Il est primordial de disposer rapidement d'une assurance continue de l'efficacité des systèmes de gestion et de contrôle des risques. En effet, les organisations sont constamment exposées à des erreurs, fraudes ou inefficiences significatives qui peuvent entraîner des préjudices financiers et relever le niveau de risque. De plus, les réformes réglementaires, la généralisation de la mondialisation, l'amélioration des opérations dictée par la pression des marchés et l'évolution rapide des conditions d'exploitation imposent d'obtenir rapidement l'assurance continue que les contrôles sont efficaces et atténuent le risque.

Ces impératifs accentuent les pressions qui s'exercent sur les responsables de l'audit interne et leurs collaborateurs. Les services d'audit interne prennent activement part à la mise en conformité aux nouvelles règles, et en particulier celles résultant de la législation, telle que la Section 404 de la loi Sarbanes-Oxley votée en 2002 aux États-Unis. Ces textes soulèvent des inquiétudes quant au relèvement du niveau d'exigence, mais aussi quant à la capacité des auditeurs internes de rester indépendants et objectifs lorsqu'ils évaluent l'efficacité des contrôles, de la gestion des risques et du gouvernement d'entreprise.

Aujourd'hui, les auditeurs internes doivent relever des défis dans plusieurs domaines[1] :

Conformité à la réglementation et contrôles : évaluation et identification des problèmes et processus, durabilité, ressources, définition de la matérialité, priorités et risques liés à la communication financière.

Qualité et indépendance de l'audit interne : attentes importantes suscitées par l'audit interne, problèmes croissants liés aux contrôles internes, confusion autour de la responsabilité et des fonctions de l'audit interne, menace sur l'objectivité et l'indépendance.

Fraude : détection et contrôle, usurpation d'identité, responsabilité de la gestion des fraudes et incidence et coûts accrus de la fraude.

Disponibilité de ressources qualifiées : manque de compétences et des qualifications requises, pénurie d'auditeurs, fidélisation et mauvaise compréhension des risques et des contrôles.

Technologie : solutions appropriées favorisant la conformité aux règles, le modèle économique technologique, sécurité de l'information, priorités concurrentes entre technologies de l'information et externalisation.

Il est évident qu'il est essentiel d'adopter une nouvelle approche, qui apportera des moyens durables, productifs et rentables de résoudre ces problèmes.

Audit continu

Traditionnellement, les auditeurs internes testent les contrôles sur une base rétrospective et cyclique, souvent plusieurs mois après les activités concernées. Les procédures de test reposent souvent sur une approche d'échantillonnage et englobent des activités telles que l'examen des politiques, procédures et autorisations ainsi que des rapprochements. Aujourd'hui, toutefois, il est admis que cette approche n'apporte aux auditeurs internes qu'un champ d'évaluation restreint, et qu'elle est souvent trop tardive pour être d'un quelconque intérêt pour les performances de l'activité ou la conformité aux règles.

L'audit continu est utilisé lorsqu'on entend procéder à une évaluation des contrôles et des risques automatiquement et à intervalles plus rapprochés. La technologie informatique joue un rôle essentiel dans la mise en œuvre d'une telle méthode.

L'audit continu modifie les paradigmes de l'audit, qui passe des examens périodiques d'un échantillon de transactions à l'audit permanent de 100 % des transactions. Il fait désormais partie intégrante de l'audit moderne à bien des niveaux. Il est aussi étroitement lié à des activités menées par le management telles que le suivi des performances, le tableau de bord équilibré et le management des risques de l'entreprise (ERM « Enterprise Risk Management »).

Une approche d'audit continu permet aux auditeurs internes de bien comprendre les points de contrôle critiques, les règles et les exceptions. Grâce à l'analyse fréquente et automatisée des données, ils sont en mesure d'évaluer les contrôles et les risques en temps réel, ou quasiment. Ils peuvent analyser les principaux systèmes des entreprises pour repérer des anomalies au niveau des transactions ainsi qu'au niveau d'indicateurs, fondés sur les données, des déficiences des contrôles et de l'apparition d'un risque. Enfin, avec l'audit continu, les résultats des analyses sont intégrés dans tous les aspects du processus d'audit, de l'élaboration et de l'actualisation du plan d'audit de l'entreprise à la réalisation d'audits en particulier, avec les mesures qui en découlent.

Le besoin d'audit/de pilotage continus : une approche intégrée

Étant donné les préoccupations que suscite, chez les responsables de l'audit interne, le fardeau représenté par les efforts de mise en conformité, la rareté des ressources et la nécessité de préserver l'indépendance de l'audit, l'idéal est de combiner audit continu et pilotage continu.

Le pilotage continu correspond aux processus que le management met en place pour veiller à ce que les politiques, procédures et processus fonctionnent efficacement. Il répond à la responsabilité qui incombe au management d'évaluer la pertinence et l'efficacité des contrôles. Il suppose

- d'identifier les objectifs des contrôles et les affirmations d'assurance,
- d'instaurer des tests automatisés pour mettre en évidence les activités et les transactions non conformes.

Nombre des techniques de pilotage continu des contrôles par le management sont identiques à celles qui peuvent être déployées par les auditeurs internes pour l'audit continu.

En recourant aux procédures de pilotage continu, en con-

[1] Rapport de la table-ronde des responsables de l'audit interne lors de la conférence internationale de l'IIA de 2005, juillet 2005.

jonction avec l'audit continu effectué par l'audit interne, le management peut s'assurer que les procédures de contrôle sont efficaces et que l'information produite pour la prise de décision est pertinente et fiable.

Autres avantages pour l'organisation, les cas d'erreur et de fraude sont généralement nettement plus rares, l'efficience opérationnelle est améliorée et les résultats de l'activité augmentent grâce aux économies réalisées sur les coûts et à la baisse des trop-payés et du manque à gagner. Les organisations qui introduisent une approche mariant audit et pilotage en continu constatent souvent que le retour sur investissement est rapide.

L'environnement des activités économiques, la réglementation et l'évolution des normes d'audit conduisent auditeurs et opérationnels à optimiser l'utilisation les systèmes d'information et d'analyse de données en tant que vecteurs essentiels de la mise en oeuvre de l'audit et du pilotage continus.

Les rôles de l'audit interne et du management

Le management a la responsabilité première d'évaluer le risque et d'élaborer, mettre en œuvre et assurer la mise à jour en continu des contrôles au sein de l'organisation.

L'audit interne est, lui, chargé d'identifier et d'évaluer l'efficacité du système de gestion des risques et des contrôles instaurés dans l'organisation par le management, afin d'apporter au comité d'audit et au management une assurance quant à l'état des risques et des systèmes de contrôle. Dans le cas des législations telles que la loi Sarbanes-Oxley, les auditeurs fournissent aussi une assurance sur la fiabilité des déclarations du management concernant l'état des contrôles. Dans l'idéal, l'audit interne ne fait pas partie du processus de pilotage des contrôles et s'abstient de concevoir ou de mettre à jour les contrôles, ce qui préserve son indépendance.

Même si la responsabilité du pilotage des contrôles internes incombe au management, l'audit interne peut tirer parti de l'audit continu pour renforcer l'environnement général de pilotage et d'examen dans une organisation.

Le niveau d'anticipation du pilotage mis en œuvre par le management influera directement sur la manière dont les auditeurs internes appréhendent l'audit continu. Lorsque le management procède à un pilotage continu des contrôles, il ne sera pas forcément nécessaire que l'audit continu adopte un niveau de test aussi détaillé sur les transactions. Les auditeurs pourront alors plutôt s'attacher aux procédures afin de déterminer l'efficacité du pilotage opéré par le management et, suivant le résultat de ces tests, ajuster l'étendue, le nombre et la fréquence des tests d'audit.

Le pouvoir de l'audit continu

Le pouvoir de l'audit continu réside dans l'existence de tests continus intelligents et efficients des contrôles et des risques, qui se traduisent par une notification rapide des écarts et des carences, afin que des mesures correctrices soient prises immédiatement. En changeant ainsi leur approche globale, les auditeurs seront mieux à même de comprendre l'environnement d'affaires et les risques qui planent sur l'entreprise, ce qui facilitera la mise en conformité avec les règles et stimulera les performances de l'entreprise.

Problèmes de mise en œuvre

Le responsable de l'audit interne doit savoir que l'audit continu va transformer le paradigme de l'audit, et notamment la nature des preuves, le calendrier, les procédures et le niveau d'effort requis des auditeurs internes. Il sollicitera le service d'audit, qui devra en particulier :

- obtenir et conserver l'appui du comité d'audit et du management pour la conception et la mise en œuvre de l'audit continu ;
- élaborer et entretenir les compétences techniques et les systèmes informatiques nécessaires pour accéder aux données contenues dans des systèmes d'information disparates, manipuler et analyser ces données ;
- utiliser (ou mettre en place) des techniques d'analyse des données en appui des missions d'audit. Ces techniques comprennent le recours aux logiciels appropriés d'analyse et le développement ainsi que la mise à jour des techniques d'analyse des données et du savoir-faire y afférent au sein de l'équipe d'audit ;
- défendre, promouvoir et encourager l'adoption de l'audit continu et le soutien du management ;
- veiller à ce que l'audit continu s'inscrive dans le cadre d'une approche intégrée et cohérente de la planification de l'audit, orientée par le risque ;
- gérer les résultats de l'audit continu, prendre les mesures qui en découlent et en déterminer les mécanismes adéquats d'utilisation, de suivi et de compte-rendu. Le responsable de l'audit interne doit veiller à ce que les constats communiqués au management soient suivis des mesures adéquates et à ce que le management tienne compte des résultats de l'audit continu lorsqu'il évalue les activités telles que le pilotage des contrôles, la mesure des performances et la gestion du risque d'entreprise.

Ce Guide pratique d'audit des technologies de l'information (GTAG) de l'IIA définit la marche à suivre pour utiliser efficacement les technologies de l'information dans le cadre de l'audit continu et souligne les aspects qui méritent une attention particulière. En lisant les sections suivantes et les méthodes qui y sont décrites, les auditeurs internes devraient être mieux préparés pour :

- tirer parti des systèmes informatiques et maximiser leur retour sur investissement ;
- démontrer au management le besoin d'investissements technologiques appropriés ;
- contribuer à la mise en conformité à la réglementation qui s'impose à leur organisation, de même qu'à sa prospérité et à sa compétitivité.

Ce GTAG se concentre sur les aspects automatisables de l'audit continu et aborde les points suivants :

- Un historique et une description du contexte dans lequel ont été utilisés des concepts analogues au cours des 30 dernières années.
- Une définition des termes et des techniques pertinents : audit continu, évaluation continue des risques, évaluation continue des contrôles, pilotage continu et assurance.
- Le rôle de l'audit continu en relation avec le pilotage continu.
- Les domaines dans lesquels l'audit interne peut appliquer l'audit continu.
- Les difficultés et les opportunités découlant de l'audit continu.
- Les conséquences pour l'audit interne, le responsable de l'audit interne et le management.
- La présentation d'un outil d'auto-évaluation de l'audit continu (annexe C, page 34).

Depuis 1980, plusieurs termes sont associés à la notion de procédure d'audit permanente, en temps réel ou quasi-réel : pilotage continu, évaluation continue des contrôles et audit continu. Ce volume des GTAG regroupe ces différentes approches au sein du concept global « d'audit continu ». Il aborde l'évaluation continue des contrôles et des risques, qui constituent l'essentiel de l'audit continu. Ce guide estime également que les activités de pilotage relèvent de la responsabilité du management, mais analyse les interdépendances entre l'audit et le pilotage et la manière dont les auditeurs internes apportent une assurance complémentaire afin d'épauler le management dans son travail.

Le coût élevé de la conformité à la réglementation constitue l'une des motivations les plus courantes et les plus visibles de l'audit continu. Aux États-Unis, une enquête internationale réalisée auprès des directeurs financiers (mars 2005)[2] chiffre le coût de la mise en conformité à la loi Sarbanes-Oxley à plus de 4 millions de dollars en moyenne par organisation. Étant donné que la plupart de ces coûts sont occasionnés par des processus manuels à forte intensité de main-d'œuvre, nécessitant l'intervention des ressources internes et de consultants externes, il n'est guère surprenant qu'une étude réalisée en janvier 2005[3] par AMR Research ait constaté que l'on peut réduire les coûts de mise en conformité de plus de 25 % en recourant à l'automatisation.

Le carcan de la conformité impose aux organisations d'améliorer leurs méthodes d'évaluation permanente des contrôles internes. Dans ce contexte, aux États-Unis, la Securities and Exchange Commission a déclaré « le management et les auditeurs doivent apporter leur jugement raisonné, ainsi qu'une approche descendante, fondée sur le risque, des processus de mise en conformité [à la Section 404 de la loi Sarbanes-Oxley] ». Cette conception conduit les organisations à apporter une attention accrue au pilotage (par le management) et à l'audit continus. Appuyant un ensemble d'activités d'audit, l'audit continu :

- permet aux auditeurs internes non seulement de donner une assurance sur les contrôles, mais aussi d'évaluer les risques et d'identifier les cas de fraude, de gaspillage et d'abus ;
- facilite la planification de l'audit ainsi que le suivi de la mise en œuvre des recommandations des auditeurs.

Audit continu : un bref historique

Les tests automatisés des contrôles remontent aux années 1960, avec l'installation et la mise en œuvre de modules d'audit intégrés (EAM - « Embedded Audit Modules »). Cependant, l'intégration et la mise à jour de ces modules étaient difficiles et peu d'organisations les ont adoptés.

À la fin des années 1970, les auditeurs ont commencé à se détourner de cette approche.

Dans les années 1980, certains ont commencé à utiliser ponctuellement les outils et techniques d'audit assistés par ordinateurs (TAAO ou CAATTs - « Computer-aided Audit Tools and Techniques ») pour des investigations et des analyses ponctuelles. Dans le même temps, la notion de pilotage continu a été présentée aux auditeurs dans un contexte largement théorique. On pensait pour l'essentiel que l'analyse automatisée des données permettrait aux auditeurs d'identifier les domaines présentant les risques les plus importants avant d'établir leurs plans d'audit. Or, la plupart des auditeurs n'étaient pas prêts à adopter ce type d'approches. Ils ne pouvaient pas accéder facilement aux outils logiciels, aux ressources et au savoir-faire techniques requis pour surmonter les problèmes d'accès aux données, et surtout, les organisations ne témoignaient pas d'une volonté de se lancer dans une approche et une méthodologie d'audit radicalement différentes.

Pendant les années 1990, les auditeurs du monde entier se sont mis à adopter les solutions d'analyse des données, critiques pour les tests de l'efficacité des contrôles internes. Cette technologie a servi à examiner les transactions à la recherche d'événements qui auraient pu se produire en raison de l'absence ou du dysfonctionnement des contrôles. Elle a également permis d'identifier les transactions non conformes aux normes des contrôles. De plus, l'analyse des données a facilité les tests des contrôles qui ne sont pas directement attestés par les données transactionnelles. Ainsi, il a été possible d'analyser les tables d'accès et d'autorisation des systèmes ERP (« Enterprise Ressource Planning » - progiciels intégrés) et d'identifier les cas où la séparation de fonctions était défaillante.

Cependant, même en s'appuyant sur cette technologie, les processus d'audit traditionnels se fondaient souvent sur des

[2] Survey on SOX Section 404 Implementation, Financial Executives International, mars 2005.

[3] SOX Decisions for 2005: Step Up Technology Investments, John Hagerty, AMR Research, janvier 2005.

échantillons représentatifs, au lieu d'évaluer une population entière, et les analyses continuaient d'être effectuées avec un décalage temporel par rapport à la fin de l'activité (transaction). Les problèmes liés aux risques et aux contrôles présentaient une plus forte probabilité de dégénérer et d'affecter les performances de l'entreprise.

L'environnement actuel de l'audit

Aujourd'hui, avec la multiplication des systèmes d'information dans l'environnement d'affaires, les auditeurs peuvent accéder plus facilement à des informations plus pertinentes, mais il leur faut également gérer et examiner des volumes nettement plus conséquents de données et de transactions.

De plus, l'accélération du rythme des affaires requiert d'identifier les problèmes de contrôle et d'y réagir rapidement. Les règles telles que la Section 404 de la loi Sarbanes-Oxley, aux États-Unis, imposent de faire rapidement part des déficiences des contrôles et des déclarations du management concernant la qualité du cadre de référence des contrôles. Cet impératif, ainsi que l'évolution permanente des normes et des logiciels d'audit, encourage et aide les auditeurs à adopter de nouvelles approches pour évaluer l'information et les contrôles.

Le responsable de l'audit interne doit être capable de communiquer à la direction générale les résultats des évaluations continues, et non de simples revues périodiques, de l'état des contrôles internes et du niveau de risque au sein de l'organisation. À l'heure actuelle, les auditeurs internes ne se contentent plus d'auditer les activités de contrôle, mais ils s'intéressent aussi au profil de risque de l'entreprise et participent activement à définir les moyens d'améliorer les processus de gestion du risque. Cependant, s'ils ne comprennent pas en détail les processus d'entreprise et les risques qui en découlent, ils se borneront à leur rôle traditionnel de vérification point par point. Avec l'audit continu, les auditeurs ont la possibilité de sortir de la sphère des approches classiques et de s'affranchir des limites imposées par les échantillons, la revue des rapports standard et les évaluations ponctuelles. L'élaboration d'un modèle de revue permanente (continue) des transactions au moment où elles interviennent, ou très rapidement après, constitue un élément crucial de l'audit continu.

Comme l'explique plus en détail la section 4, selon que le management a ou non mis en œuvre des systèmes de pilotage continu des contrôles, qui identifient les carences des contrôles et fournissent des indicateurs de risque, l'approche déployée par les auditeurs vis-à-vis de l'audit continu ne sera pas la même.

L'audit continu mesure des attributs spécifiques qui inciteront l'auditeur à agir si certains paramètres sont réunis. Il regroupe deux grandes activités :

- L'évaluation continue des contrôles, qui attire dès que possible l'attention des auditeurs sur les défaillances des contrôles.
- L'évaluation continue du risque, qui fait ressortir les processus et les systèmes qui affichent un niveau de risque supérieur à celui qui est prévu.

La fréquence de l'activité d'audit continu dépend du risque intrinsèque au sein du processus ou du système. De plus, il est possible de commencer en examinant les principaux contrôles et les principales catégories de risques, puis d'élargir l'application de l'audit continu à mesure que les auditeurs acquièrent de l'expérience et obtiennent des résultats mesurables qui contribuent à la conformité aux règles, à l'efficience et à l'efficacité opérationnelles, ainsi qu'à l'intégrité de la communication financière.

Référentiel du COSO sur le management des risques de l'entreprise (COSO ERM)

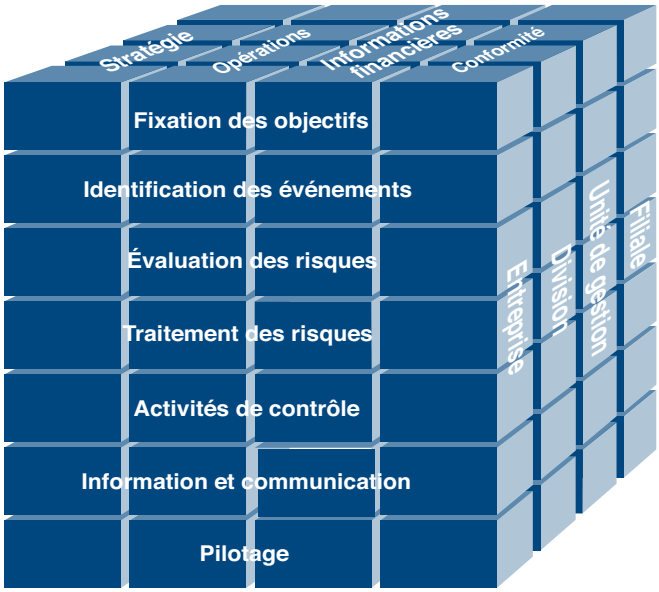
Le référentiel intitulé *Le management des risques de l'entreprise – Cadre de référence (Enterprise Risk Management (ERM) Framework)*, du Committee of Sponsoring Organizations of the Treadway Commission (COSO), encourage les auditeurs internes à aborder leurs activités de la même façon que le management dirige une entreprise :

- environnement de contrôle,
- évaluation des risques,
- information et communication,
- pilotage des risques.

Le référentiel du COSO ERM s'inscrit dans le prolongement du référentiel initial élaboré par le COSO sur le contrôle interne (La nouvelle pratique du contrôle interne). Il met davantage l'accent sur les contrôles internes et propose une discussion plus approfondie sur le vaste sujet de l'ERM. Il définit quatre objectifs (stratégie, opérations, communication et conformité) qui poussent les auditeurs internes à évaluer le système de contrôles internes et à identifier et mesurer le risque. À cette fin, les auditeurs internes doivent abandonner leur rôle traditionnel pour s'attacher aux objectifs, aux stratégies, à la gestion du risque et aux processus de l'entreprise, ainsi qu'aux activités de contrôle critiques.

L'audit continu ne s'intéresse pas uniquement à la conformité aux contrôles et à la réglementation, mais cherche aussi à améliorer l'efficience des opérations de l'organisation. Il doit également contribuer à l'amélioration globale de l'organisation en identifiant et mesurant le risque et en communiquant au management des informations qui lui permettront de mieux réagir à l'évolution de l'environnement d'affaires. Il facilite le travail de l'audit interne dans tous les composants de l'ERM définis par le COSO :

- Environnement interne et fixation des objectifs : en formalisant les objectifs de l'audit continu et le rôle de l'audit interne.
- Identification des événements en élaborant :
  - un système permettant de repérer et de signaler les événements,
  - un processus traitant ces menaces et opportunités.



Cadre de référence du management des risques de l'entreprise du COSO

- Évaluation des risques :
  - en analysant et en évaluant le risque,
  - en tenant compte de sa vraisemblance et de son impact, ce qui permettra de déterminer comment le risque doit être géré.
- Traitement des risques :
  - en tenant compte des catégories de risques et des principales activités à risque,
  - en élaborant des méthodes fondées sur les données informatisées pour évaluer les risques et y réagir.
- Activités de contrôle :
  - en reconnaissant les rôles du management et des auditeurs internes,
  - en démontrant que l'évaluation des contrôle n'est pas une activité qui s'effectue une fois par an, mais un processus permanent,
  - en automatisant les tests des contrôles en temps réel ou aussi proches que possible du temps réel.
- Information et communication : en contribuant à l'exactitude de l'information et à la rapidité de la communication des problèmes.
- Pilotage : en procurant une évaluation indépendante en soutient des activités de pilotage mises en œuvre par le management.

L'évaluation continue des contrôles permet aux auditeurs internes de se faire une idée de la qualité des activités de pilotage mises en œuvre par le management. Il apporte au comité d'audit et à la direction générale une assurance indépendante que les contrôles fonctionnent correctement et que l'organisation peut réagir rapidement pour remédier aux défaillances qui se produisent.

Grâce à l'évaluation continue des risques, les auditeurs peuvent identifier les domaines qui sont susceptibles de faire courir un risque à l'entreprise, classer ces risques par ordre de priorité et répartir plus efficacement des ressources d'audit limitées.

Cependant, ces activités ne sauraient en aucun cas dégager le management de sa responsabilité d'exécuter sa fonction de pilotage et de gérer le risque.

Le pilotage constitue le dernier élément défini par le référentiel du COSO pour l'ERM en vue d'un cadre de contrôle efficace. Il joue un rôle primordial dans les efforts d'amélioration continue de l'organisation. Le pilotage continu englobe les processus que le management met en place pour que les politiques, les procédures et les processus de l'entreprise fonctionnent correctement. Il découle de la responsabilité d'évaluer le bien-fondé et l'efficacité des contrôles, qui échoit au management. Il suppose :

- d'identifier les objectifs des contrôles et les assertions d'assurance ;
- d'instaurer des tests automatisés pour mettre en évidence les transactions non conformes aux objectifs de contrôle et aux assertions d'assurance pertinents.

Nombre des techniques de pilotage continu des contrôles par le management sont analogues à celles qui peuvent être employées pour l'audit continu par le service d'audit interne.

Les rôles de l'audit interne et du management

Dans son activité de garant du bon fonctionnement de l'entreprise, le management a la responsabilité première d'évaluer le risque et de concevoir, mettre en œuvre et actualiser les contrôles au sein de l'organisation.

À la lumière de ses responsabilités vis-à-vis du management et du Conseil d'administration, l'activité d'audit interne est chargée de surveiller et d'évaluer l'efficacité du système de management des risques de l'organisation et les contrôles mis en œuvre par le management.

La différence entre les rôles de l'audit interne et ceux du management concernant les contrôles internes et le risque réside dans la nature des responsabilités vis-à-vis des parties prenantes. Les auditeurs conduisent l'évaluation afin d'apporter une assurance aux parties prenantes, au comité d'audit et à la direction générale concernant l'état du risque et des systèmes de contrôle et, dans le cadre de législations telles que la loi Sarbanes-Oxley, quant à la fiabilité des déclarations du management à propos de l'état des contrôles. Dans l'idéal, les auditeurs ne font pas partie du processus et ne participent ni à la conception ni à l'actualisation des contrôles, ce qui leur permet de rester objectifs et indépendants.

Avantages de l'audit et du pilotage continus

Les résultats produits par l'audit et le pilotage continus (par le management) sont semblables et supposent d'envoyer des notifications ou des alertes afin de faire état des défaillances des contrôles ou d'une augmentation du niveau de risque. Il est possible de classer ces notifications et ces alertes par

ordre de priorité et en fonction de la gravité du risque ou de la défaillance du contrôle, de les diffuser aux garants des processus d'entreprise ou des systèmes d'application, au management opérationnel, aux auditeurs, aux directeurs financiers et même aux instances de réglementation. Pour réagir à ces notifications, le management peut remédier à la défaillance du contrôle ou corriger immédiatement une transaction erronée. L'audit interne, lui, pourra aller de l'identification d'un périmètre d'audit futur jusqu'à la réalisation immédiate d'un audit du système de contrôle incriminé.

Par exemple, les tests d'audit continu effectués sur les transactions financières peuvent aboutir à une alerte lorsqu'une pièce justificative d'un journal dépasse une limite donnée et implique une combinaison inhabituelle de comptes. La réaction de l'audit ne sera pas la même s'il estime qu'il s'agit d'un problème ponctuel, auquel cas il enverra un courrier électronique à l'entité à l'origine de la transaction pour lui demander des explications, ou d'un problème systémique, auquel cas il faudra peut-être envisager un audit financier. Dans le cadre d'un audit continu, les tests supplémentaires destinés à déterminer la nature de l'anomalie pourraient permettre de répondre aux questions suivantes :

- La pièce justificative du journal crée-t-elle une entrée dans un compte d'attente qui n'est pas soldée dans un délai raisonnable ?
- La pièce justificative du journal crée-t-elle des entrées dans une combinaison inhabituelle de comptes ?
- Les comptes concernés sont-ils ceux qui seraient susceptibles de gonfler artificiellement le résultat de l'entreprise, par exemple ?
- Les volumes et le type des pièces justificatives sont-ils inhabituels par rapport à ceux des exercices précédents ?
- Les individus qui saisissent les écritures se trouvent-ils dans une situation où la séparation des fonctions est compromise ?
- Devrions-nous resserrer ou au contraire assouplir les critères pour ce test ?
- Les ratios financiers sont-ils comparables à ceux d'entreprises similaires ?
- Quelle est la tendance du résultat ces dernières années, et comment se situe-t-elle par rapport à celle d'entreprises comparables, et à l'environnement économique en général ?

L'audit continu aide les auditeurs à évaluer la qualité de la fonction de pilotage mise en œuvre par le management. Le responsable de l'audit interne peut ainsi apporter au comité d'audit et à la direction générale l'assurance indépendante que les systèmes de contrôle fonctionnent correctement et que des processus d'audit sont en place pour identifier tout manquement et y remédier. De plus, l'audit continu identifie et évalue des domaines de risques, et fournit aux auditeurs des informations qui pourront être transmises au management pour contribuer aux mesures de réduction du risque. Enfin, il peut se révéler utile lors de l'élaboration du plan d'audit annuel, car il permet de recentrer l'attention et les ressources d'audit sur les périmètres les plus risqués.

Cependant, l'un des principaux avantages de l'audit continu réside dans son indépendance vis-à-vis :

- des systèmes opérationnels et financiers sous-jacents ;
- du pilotage exécuté par le management.

Cette indépendance améliore les cadres de gestion et de contrôle de l'organisation et fournit des mécanismes utilisables par les auditeurs pour leurs propres activités de revue et d'évaluation.

L'audit continu ne va toutefois pas sans poser de difficultés. Il convient tout d'abord de comprendre et de maîtriser la technologie. Les auditeurs internes doivent avoir accès aux données, aux outils logiciels et aux techniques, mais aussi avoir acquis le savoir nécessaire pour employer intelligemment les volumes importants de données financières et non financières à leur disposition. Les opportunités offertes par l'audit continu se traduisent aussi par des exigences supplémentaires vis-à-vis des auditeurs et du responsable de l'audit interne.

On a tenté à diverses reprises d'encourager les auditeurs à faire un meilleur usage de l'information électronique et à améliorer l'efficience et l'efficacité de l'activité d'audit interne. Plus récemment, un large éventail de termes a été utilisé pour qualifier ces initiatives, et ont semé la confusion dans la profession. Sans une terminologie claire et commune, il sera difficile de promouvoir ces initiatives et leurs chances de succès s'amenuiseront. Pour la mise en œuvre de l'audit continu, il convient donc de commencer par élaborer et diffuser une définition claire pour tous les termes y afférents.

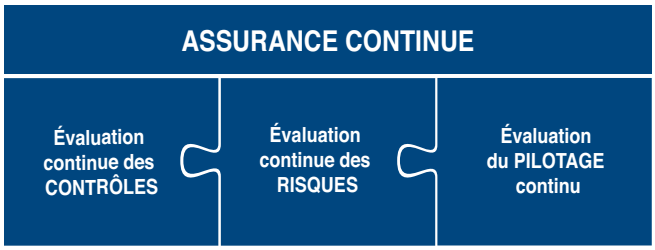
Pour bien appréhender la terminologie de l'audit continu, il faut comprendre que le **contrôle** et le **risque** représentent les deux faces d'une même médaille. Les contrôles servent à réduire le risque et l'identification des défaillances des contrôles met en évidence les risques potentiels. Inversement, en examinant le risque, les auditeurs peuvent déterminer où des contrôles sont nécessaires et/ou ne sont pas opérationnels.

Bien que l'évaluation des contrôles et des risques fasse toujours intervenir une analyse qualitative et quantitative, c'est en maximisant l'utilisation de la technologie que l'on obtient les gains d'efficience les plus importants. Pour les auditeurs, il s'agit de faire en sorte que les données soient disponibles et utiles, de comprendre les processus et les systèmes sous-jacents et de maximiser le recours à l'automatisation. C'est pourquoi ce GTAG s'attache aux processus assistés par ordinateur qui facilitent l'audit continu.

L'**assurance** peut être considérée comme une opinion donnée à un tiers concernant l'état des affaires, que ce soit sur une transaction, un processus ou la gouvernance d'une activité, d'un risque ou les performances financières globales d'une opération. L'assurance de l'audit est une déclaration sur le bien-fondé et l'efficacité des contrôles et sur l'intégrité de l'information.

Le **pilotage continu des contrôles** par le management se trouve au cœur des stratégies d'assurance efficaces. Les auditeurs doivent néanmoins veiller à ce que les activités du management soient adéquates et efficaces. Le cadre de l'assurance continue combine les activités relevant de l'audit interne et qui visent à évaluer en toute indépendance :

- l'état des contrôles,
- la gestion du risque dans l'organisation,
- l'évaluation de l'adéquation de la fonction de pilotage exécutée par le management.



Le responsable de l'audit interne doit veiller à ce que tous les auditeurs, la direction générale et le comité d'audit comprennent bien les rôles et les responsabilités de l'audit interne et du management dans leur effort pour obtenir une équation d'audit continu efficace. Les définitions suivantes peuvent apporter quelques éclaircissements :

- **L'audit continu** désigne toute méthode utilisée par les auditeurs pour accomplir leurs activités d'audit de manière plus continue ou continuelle. C'est le continuum des activités qui vont de l'évaluation continue des contrôles à **l'évaluation continue des risques**, c'est-à-dire le continuum contrôles-risques. La technologie joue un rôle déterminant dans :
  - l'automatisation de l'identification des exceptions et/ou des anomalies,
  - l'analyse de schémas identifiables (patterns) relatifs aux chiffres au sein de champs numériques critiques,
  - l'analyse des tendances,
  - l'analyse détaillée des transactions à l'aide de plafonds et de seuils,
  - les tests des contrôles,
  - la comparaison des processus et des systèmes sur la durée et/ou avec d'autres entités similaires.
- **L'évaluation continue des contrôles** fait référence aux activités utilisées par les auditeurs pour apporter une assurance sur les contrôles.

  Par l'évaluation continue des contrôles, les auditeurs donnent au comité d'audit et à la direction générale l'assurance que les contrôles fonctionnent bien, en identifiant les faiblesses et les violations des contrôles.

  Chaque transaction est pilotée sur la base d'un ensemble de règles de contrôle destinées à apporter une assurance sur le système de contrôles internes et à mettre en évidence les exceptions.

  Un corpus de règles de contrôle bien défini permet de donner l'alerte rapidement lorsque les contrôles sur un processus ou un système ne fonctionnent pas comme prévu ou ont été compromis.

  Selon que le management remplit avec plus ou moins de sérieux ses responsabilités de pilotage continu, l'audit interne devra mener des activités d'évaluation continue des contrôles plus ou moins poussées. Lorsque le management met en œuvre un système de pilotage solide, les auditeurs n'auront pas besoin de procéder à des tests très détaillés pour apporter une assurance sur les contrôles.
- **L'évaluation continue des risques** fait référence aux activités des auditeurs pour identifier et évaluer les niveaux de risque.

  L'évaluation continue des risques identifie et évalue les risques :
  - en examinant les tendances,
  - en procédant à des comparaisons, au sein d'un processus ou d'un système, par rapport aux performances passées et par rapport aux autres processus et systèmes en place dans

l'entreprise.

Par exemple, on peut comparer les performances d'une ligne de produits à celles de l'exercice précédent, mais aussi comparer les performances d'une usine à celles de toutes les autres. Ces comparaisons permettent de savoir rapidement qu'un processus ou un système donné présente un niveau de risque en hausse par rapport aux années précédentes, ou aux autres entités.

L'activité d'audit réagira différemment suivant la nature et le niveau du risque. On peut recourir à l'évaluation continue des risques dans un audit étendu afin de sélectionner les sites à visiter, d'identifier les audits ou les entités spécifiques à inclure dans le plan d'audit annuel, ou de déclencher l'audit immédiat d'une entité dont le risque s'est significativement accru sans explication convaincante. On peut aussi y recourir afin d'évaluer les interventions du management, de vérifier si les recommandations des auditeurs ont été correctement suivies et si elles réduisent le niveau de risque dans l'entreprise.

- **Le pilotage continu** est un processus que le management met en place pour que sa politique, ses procédures et les processus d'entreprise fonctionnent correctement.

  Le management identifie les points de contrôle critiques et met en œuvre des tests automatisés afin de déterminer si ces contrôles fonctionnent bien. Le pilotage continu suppose d'exécuter des tests automatiques de toutes les transactions et les activités du système, dans le cadre d'un processus d'entreprise donné, sur la base d'une succession de règles de contrôle. Le pilotage est habituellement effectué sur une base quotidienne, hebdomadaire ou mensuelle, suivant la nature du cycle économique sous-jacent. Par l'usage de règles de contrôle, de paramètres de tests et des seuils correspondants, certaines transactions sont marquées comme étant des exceptions de contrôle et le management en est informé.

  La fonction de pilotage du management fait également appel aux indicateurs clés de performance (ICP pour KPI - « Key Performance Indicators ») et autres activités de mesure de performances. Il incombe au management de réagir aux alertes et aux notifications résultant de ce pilotage, de remédier à toute défaillance des contrôles et de corriger les transactions concernées.

Le continuum de l'audit continu

Grâce à l'audit continu, l'auditeur peut identifier et évaluer le risque et instaurer des seuils intelligents et dynamiques qui répondent aux changements au sein de l'organisation.

L'audit continu facilite aussi l'identification et l'évaluation des risques pour tout l'univers de l'audit, contribuant à l'élaboration du plan d'audit annuel comme à celle des objectifs d'un audit en particulier. Comme tel, Il peut être considéré comme un continuum opérant à différents niveaux.

Par ailleurs, différents points sur le continuum conviennent mieux à différentes tâches. Il est ainsi possible de se situer sur plus d'un point du continuum lorsqu'on exécute certaines tâches.

L'audit continu s'étend du contrôle au risque (voir diagramme plus bas). Les techniques d'analyse s'échelonnent de l'examen en temps réel des transactions détaillées à l'analyse des tendances et à la comparaison des entités entre elles et sur la durée.

- À l'extrémité du continuum consacrée aux contrôles, les activités d'audit englobent l'assurance sur les contrôles et les vérifications financières.
- Lorsqu'on passe à l'autre extrémité du continuum, les activités d'audit vont de l'identification des cas de fraude, de gaspillage et d'abus jusqu'à l'évaluation des risques visant à faciliter le déroulement des missions d'audit et de la production du plan d'audit annuel.
- Les activités du management y afférentes englobent le pilotage continu des contrôles, le pilotage des

← Audit continu →						
Évaluation continue des contrôles ←				→ Évaluation continue des risques		**Approche**
Fondé sur les contrôles (les contrôles destinés à apporter une assurance fonctionnent) Contrôles financiers ←				→ Fondé sur les risques (identification/évaluation des risques) Contrôles financiers/opérationnels		**Cible**
Tests des transactions détaillées/en temps réel (données financières) ←				→ Comparaison/tendances (données financières/opérationnelles)		**Techniques d'analyse**
Assurance sur les contrôles	**Vérification financière**	**Fraude/ gaspillage/ abus**	**Périmètre et objectifs de l'audit**	**Suivi des recom. de l'audit**	**Plan d'audit annuel**	**Activités de l'audit y afférentes**
Pilotage des contrôles	**Pilotage des performances**		**Tableau de bord équilibré**	**Gestion de la qualité totale (TQM)**	**Tableau de bord équilibré**	**Activités du management y afférentes**

performances, le tableau de bord équilibré, la gestion de la qualité totale et le management du risque (ERM).

L'audit continu constitue une structure ou un cadre homogène qui réunit l'assurance sur les contrôles, l'évaluation des risques, la planification de l'audit, l'analyse numérique et les autres outils, techniques et technologies d'audit. Il entre en jeu dans la problématique :

- du micro-audit, par exemple pour les tests des transactions détaillées visant à évaluer l'efficacité des contrôles,
- du macro-audit, par exemple sur le recours à l'identification et à l'évaluation des risques en vue d'élaborer le plan d'audit annuel.

Il intervient aussi au niveau intermédiaire, par exemple pour le développement des objectifs de chaque mission d'audit.

La principale différence entre les niveaux micro et macro de l'audit réside dans la granularité de l'information requise :

- Les tests des contrôles nécessitent des informations détaillées, qui sont à chercher à la source des transactions. L'évaluation continue des contrôles recourt à des règles élaborées avec soin et aux tests des transactions en temps réel ou proches du temps réel pour pouvoir respecter ces règles.
- Les audits commencent souvent par les risques identifiés dans le plan d'audit annuel, mais utilisent des analyses de données plus détaillées et d'autres techniques (par exemple des interviews, des auto-évaluations des contrôles, des revues de processus, des questionnaires, etc.) afin de définir plus avant les principales catégories de risque et de recentrer l'évaluation des risques et les activités d'audit ultérieures.
- Le plan d'audit annuel requiert des informations de haut niveau, peut-être des données courant sur plusieurs exercices, pour pouvoir déterminer les facteurs de risque, classer les risques par ordre de priorité et fixer le calendrier et les objectifs initiaux des audits planifiés.

Assurance continue

Comme indiqué plus haut, l'assurance peut être considérée comme l'opinion donnée à un tiers concernant l'état des affaires. Elle fait généralement intervenir trois parties:

- la personne ou le groupe qui élabore l'information,
- la personne ou le groupe qui utilise l'information pour prendre des décisions,
- la tierce partie objective.

On considère souvent que l'assurance relève strictement de l'audit, et que c'est une activité de nature financière. Cependant, des juristes, par exemple, peuvent également apporter des services d'assurance.

L'assurance d'audit est une déclaration concernant l'adéquation et l'efficacité des contrôles et l'intégrité de l'information. Le pilotage continu des contrôles par le management se situe au cœur d'une stratégie d'assurance efficace ; toutefois, l'audit doit aussi veiller à ce que les activités du management soient adéquates et efficaces.

L'audit interne fournit des services d'assurance en procédant à l'examen objectif des preuves en vue d'évaluer en toute indépendance :

- les stratégies et les pratiques de gestion des risques,
- le cadre et les pratiques de contrôle du management,
- l'information utilisée pour la prise de décision et la communication financière.

Les auditeurs apportent une assurance continue lorsqu'ils effectuent une évaluation continue des contrôles et des risques (donc un audit continu) et évaluent la pertinence des activités de pilotage continu du management.
Les auditeurs :

- examinent les activités menées à bien par le management, vérifient que les contrôles fonctionnent,
- recommandent des changements et s'assurent que le risque est géré.

Si les auditeurs font leur travail (c'est-à-dire vérifient les contrôles et les risques ainsi que les activités de pilotage du management), l'organisation disposera d'une meilleure assurance que :

- les contrôles fonctionnent,
- les risques sont gérés,
- l'information utilisée pour la prise de décision est intègre.

Le management joue un rôle dans cette équation en élaborant, en concevant et en surveillant les contrôles, ainsi qu'en gérant les risques.

Pilotage continu

Le pilotage continu désigne les processus que le management met en place pour que les règles, les procédures et les processus fonctionnent efficacement. Il découle de la responsabilité du management d'évaluer la pertinence et l'efficacité des contrôles. Nombre des techniques de pilotage continu des contrôles par le management sont identiques à celles qui peuvent être déployées par les auditeurs internes pour l'audit continu. Les principes du pilotage continu sont simples et comprennent :

- la définition des points de contrôle au sein d'un processus donné, si possible dans le cadre de l'ERM fixé par le COSO ;
- l'identification des objectifs de contrôle et des assertions d'assurance pour chaque point de contrôle;
- l'instauration une série de tests automatisés qui indiqueront si une transaction donnée paraît non-conforme aux objectifs de contrôle et aux assertions d'assurance pertinents ;
- la soumission de toutes les transactions à cette série de tests aussi rapidement que possible après l'exécution de ces transactions ;
- l'étude de toute transaction qui semble ne pas passer un test avec succès ;
- la correction de la transaction, le cas échéant ;
- la réfection de la faiblesse du contrôle, si nécessaire.

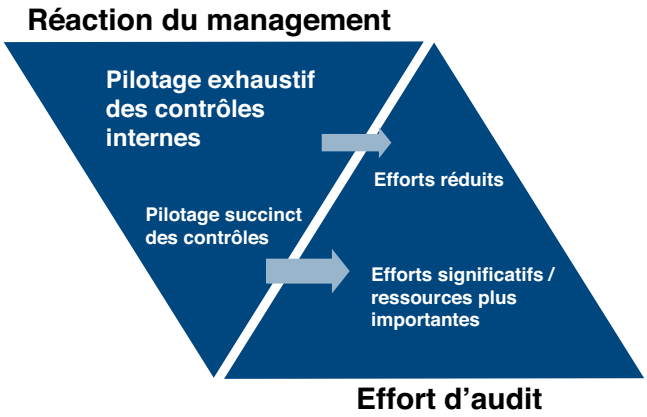
Dans le pilotage continu, il est impératif que ce soit le management qui soit le propriétaire du processus et qui l'exécute, dans le cadre de son obligation de mettre en œuvre et de maintenir des contrôles efficaces. Étant donné que le management est responsable des contrôles internes, il doit avoir les moyens de déterminer, sur une base permanente, si ces contrôles fonctionnent comme prévu. Lorsqu'on peut identifier et corriger rapidement les problèmes de contrôle, il est possible d'améliorer le système de contrôle dans son ensemble.

Autres avantages pour l'organisation, les cas d'erreur et de fraude se font nettement plus rares, l'efficience opérationnelle est améliorée et les résultats de l'activité augmentent grâce aux économies réalisées sur les coûts et à la baisse des trop-payés et du manque à gagner.

Audit continu

Il existe une relation inversement proportionnelle entre:

- d'une part la pertinence des activités de pilotage et de gestion du risque effectués par le management
- d'autre part la granularité des tests des contrôles et d'évaluation des risques diligentés par les auditeurs.



Le niveau d'effort du management et l'activité d'audit : une relation inversement proportionnelle

Ainsi, l'approche et l'ampleur des activités d'audit continu dépendent du niveau de qualité du pilotage continu déployé par le management.

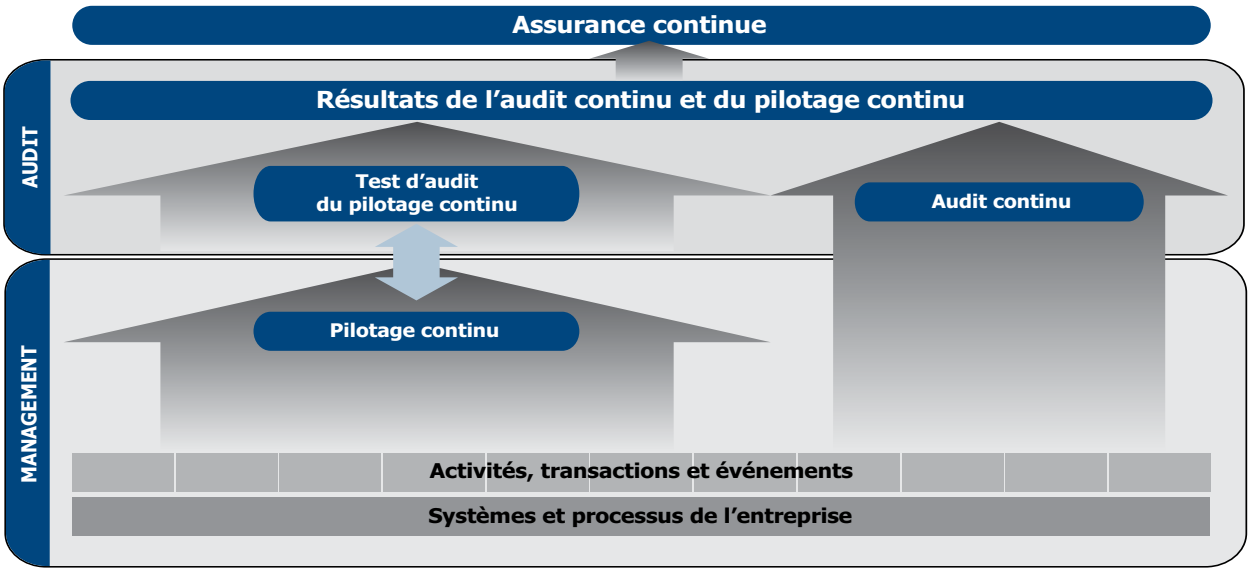
Dans les domaines où le management n'a pas mis en œuvre de pilotage continu, les auditeurs doivent procéder à des tests détaillés en recourant aux techniques d'audit continu. Dans certains cas, les auditeurs peuvent même prendre les devants et aider l'organisation en instaurant des processus de management des risques et d'évaluation des contrôles. Cependant, il convient de veiller à ce que les auditeurs n'endossent pas la propriété de ces processus, ce qui risquerait de compromettre leur indépendance ou leur objectivité.

Lorsque le management procède à un pilotage continu sur une base complète, d'un bout à l'autre des processus, il ne sera pas forcément nécessaire que l'audit interne déploie des techniques aussi détaillées qu'il ne le ferait sinon dans le cadre de l'audit continu. Les auditeurs pourront alors plutôt s'attacher à d'autres procédures afin de déterminer s'ils peuvent se fier au pilotage continu. De telles procédures comprennent :

- l'examen des anomalies détectées et de la réaction du management ;
- l'examen et test des contrôles sur le processus même de pilotage continu, par exemple :
  - journaux de traitement/pistes d'audit,
  - rapprochements des totaux de contrôle,
  - changements apportés aux paramètres de test du système.

De manière générale, ces procédures sont analogues aux tests de contrôle de la qualité effectués durant le processus normal de l'audit pour vérifier que les techniques d'audit assistées par ordinateur (TAAO ou CAATs) sont appliquées correctement.

En évaluant les résultats combinés du pilotage continu et des processus d'audit, les auditeurs peuvent apporter une assurance continue concernant l'efficacité des contrôles internes.



Audit, pilotage et assurance continus (modèle conceptuel)

Les services d'audit interne subissent une contrainte croissante d'en faire toujours davantage avec toujours moins de moyens. Le plus difficile pour les auditeurs internes consiste peut-être à apporter en temps opportun l'assurance de l'efficacité des contrôles internes, à mieux identifier et évaluer le niveau de risque et à mettre rapidement en évidence les cas de non-conformité vis-à-vis des réglementations et de la politique de l'organisation.

Or, l'audit continu peut s'appliquer à toutes ces activités. Les technologies utilisées vont des tableurs ou encore des scripts élaborés à l'aide de logiciels d'audit spécialisés aux progiciels en usage, en passant par les systèmes développés sur mesure. La solution retenue doit être flexible et évolutive et permettre aux auditeurs de commencer par un aspect donné puis d'élargir le périmètre et l'échelle et d'augmenter la fréquence de l'analyse.

Bien que certains audits doivent obligatoirement être effectués sur une base annuelle, ce rythme strictement annuel ne correspond plus aux exigences du management et de la réglementation. L'audit interne doit mener l'évaluation des risques et l'assurance sur les contrôles au fil de l'eau.

Si la réglementation s'attache de plus en plus aux aspects financiers de l'audit, l'audit continu s'applique à tous les types d'audit et à tous les aspects de cette activité. En 2005, dans un document intitulé *Internal Auditing in Europe*[4], la Confédération européenne des Instituts d'audit interne (ECIIA) encourageait les auditeurs internes à répondre aux risques auxquels se trouvait confrontée leur organisation en apportant au management l'assurance que ces risques avaient été identifiés et étaient gérés correctement.

Les auditeurs doivent être capables d'examiner et d'évaluer les risques non seulement financiers, mais aussi opérationnels et stratégiques, ce qui constitue un nouveau domaine pour l'audit continu. Les technologies de l'information et les compétences techniques utilisées pour tester les contrôles peuvent également aider le responsable de l'audit interne à apporter une aide précieuse au management en facilitant l'évaluation continue de l'efficacité des activités d'ERM et en recommandant des améliorations, si nécessaires.

Le responsable de l'audit interne contribue à la fonction de pilotage en communiquant à la direction générale des évaluations indépendantes des risques et des contrôles. L'audit continu dispose d'un éventail de fonctionnalités qui soutiennent les activités d'audit et leur responsable via les méthodes et les services suivants :

- stratégies et pratiques du management des risques, par une identification précoce des risques ;
- fiabilité du cadre de contrôle du management, par une mise en évidence des faiblesses des contrôles ;
- information pour la prise de décision, par un examen de la fiabilité et de l'accessibilité des informations utilisées par le management ;
- sélection des missions d'audit à intégrer dans le plan d'audit annuel, par une identification des domaines les plus risqués ;
- mise en œuvre rapide de mesures correctives efficaces, par une vérification de l'application des recommandations formulées par les auditeurs.

Le responsable de l'audit interne doit admettre qu'il existe plusieurs démarches prises à l'initiative du management qui entretiennent des liens étroits avec l'audit continu. Il s'agit par exemple du management intégré des risques, des tableaux de bord équilibrés, de l'amélioration continue et du pilotage continu. Les auditeurs doivent déterminer où l'audit continu peut être appliqué et comment il peut être utilisé pour évaluer ces initiatives du management ou employer les informations qu'elles génèrent.

La mise en œuvre d'un cadre d'audit continu s'accompagne des avantages suivants :

- plus grande capacité à atténuer les risques ;
- réduction du coût de l'évaluation des contrôles internes ;
- plus grande confiance dans les résultats financiers ;
- amélioration des opérations financières ;
- diminution du nombre des erreurs financières et des possibilités de fraude.

De plus, les organisations qui ont pleinement opté pour l'audit continu font généralement état d'une baisse de leurs coûts d'exploitation et d'une augmentation de leur marge bénéficiaire.

Applications de l'évaluation continue des contrôles

Identification des défaillances des contrôles

Avec l'adoption de nouvelles réglementations imposant à la direction générale des entreprises d'attester, documents à l'appui, de l'efficacité de leur environnement de contrôle et de l'exactitude des informations contenues dans leurs rapports financiers, les directeurs généraux et les directeurs financiers demandent à l'audit interne de les aider à se mettre en conformité avec ces nouvelles règles.

Même s'il est généralement admis que la direction générale est responsable du pilotage, de la conception et de l'actualisation des contrôles, la Norme 2130 de l'IIA précise que l'activité d'audit interne doit évaluer la pertinence et l'efficacité du dispositif de contrôle choisi pour faire face aux risques relatifs au gouvernement d'entreprise, aux opérations et systèmes d'information de l'organisation.

En raison de ces pressions externes et internes, particulièrement dans les cas où le management ne prend pas les devants pour assumer son rôle de pilotage, on attend souvent des auditeurs qu'ils se livrent à une évaluation plus poussée et plus

[4] *Internal Auditing in Europe*, ECIIA, février 2005.

continue des contrôles. Ces pressions influent considérablement sur les processus et les méthodes de l'audit interne.

L'évaluation continue des contrôles donne aux responsables de l'audit interne une idée claire de l'efficacité des systèmes de contrôle interne. Les cadres financiers, les responsables des processus et les directeurs des risques et de la conformité disposent ainsi d'une assurance rapide et indépendante à propos des contrôles internes. L'évaluation continue des contrôles sur les données transactionnelles permet de mettre rapidement en évidence les erreurs et les anomalies, et d'en faire immédiatement part au management, en vue d'un examen et de mesures correctives. Elle peut également contribuer à la fiabilité et à l'intégrité des informations financières et opérationnelles et à l'efficience et l'efficacité des opérations.

L'évaluation continue des contrôles peut également faciliter l'évaluation permanente des risques et des mesures prises par le management pour les réduire. Les évaluations des contrôles et des risques constituent des activités complémentaires, qui se soutiennent mutuellement.

La section qui suit décrit des exemples de scénarios dans lesquels l'activité d'audit interne évalue les contrôles en continu pour compléter la fonction de pilotage du management dans trois domaines : contrôles financiers, contrôles des systèmes informatiques et contrôles de la sécurité.

Contrôles financiers : exemple des programmes de cartes de paiement

Le responsable national des cartes de paiement examine manuellement un petit échantillon de transactions chaque trimestre. Les auditeurs déterminent que les contrôles du management sur les achats sont faibles et que l'exposition potentielle au risque est relativement élevée. Après avoir examiné la politique applicable pour l'utilisation des cartes de paiement, les auditeurs élaborent une série de tests analytiques visant à identifier :

- l'usage inapproprié des cartes, y compris les transactions liées aux frais de déplacement ;
- les achats de biens personnels (par exemple bijoux, alcool, etc.) ;
- les transactions douteuses (par exemple, l'usage des cartes par des utilisateurs non autorisés, le double passage dans la machine par le commerçant, les achats scindés pour contourner les plafonds de dépenses, etc.).

Les résultats des analyses sont envoyés aux supérieurs de chaque titulaire de carte afin qu'ils procèdent à un examen détaillé des achats suspects, par un rapprochement entre les facturettes des cartes et les biens achetés. Cette procédure permet d'identifier plusieurs achats inappropriés et trois cas de fraude.

Après la fin de l'audit, les programmes de tests de l'évaluation continue des contrôles sont remis au coordinateur des cartes de paiement afin qu'il aide le management opérationnel à piloter les contrôles des achats par carte sur une base mensuelle.

Contrôles des systèmes informatiques : exemple de séparation des fonctions

Il est également possible de lancer des tests de l'évaluation continue des contrôles afin de vérifier que les contrôles des systèmes fonctionnent comme prévu. Recourant à une technologie analytique, ces tests confrontent chaque transaction à des critères fondés sur des règles en examinant toutes les transactions afin de vérifier que des individus n'exercent pas des fonctions incompatibles.

Par exemple, au sein d'une organisation, la mise en œuvre d'un nouveau système d'ERP (progiciel de gestion intégré) est censée remplacer les contrôles manuels par des contrôles automatisés, afin de veiller à la séparation des fonctions. Avec la participation des propriétaires de l'activité, l'équipe de mise en place de l'ERP élabore un ensemble de profils utilisateurs, fondés sur les rôles, définissant des autorisations pour les diverses catégories de transactions que chaque utilisateur peut exécuter dans le cadre de ses fonctions. Bien que les auditeurs soient satisfaits de l'approche et des processus intervenant dans l'élaboration de ces profils, ils sont préoccupés par l'attribution concrète des profils aux utilisateurs et procèdent à un examen détaillé des transactions, à la recherche de cas où la séparation des fonctions ne serait pas assurée.

Les auditeurs se procurent un extrait de toutes les transactions traitées pendant le premier trimestre de l'exercice et recourent à une technique d'analyse des données pour calculer le nombre de transactions traitées par chaque utilisateur, par catégorie de transactions. Ils identifient deux utilisateurs qui ont commencé par créer des bons de commande puis ont enregistré des transactions de réception des marchandises pour les bons de commande en question. Ces résultats indiquent la présence de faiblesses dans le contrôle sur la séparation des fonctions au niveau de la conception des profils, car ces deux fonctions sont jugées incompatibles.

À mesure que le système d'ERP subit des changements, par exemple l'ajout de nouveaux rôles ou la modification des rôles existants, les tests d'évaluation continue des contrôles permettent de vérifier que la séparation des fonctions reste bien respectée dans tous les cas.

Contrôles de la sécurité : exemple des journaux d'accès au système

L'évaluation continue des contrôles peut tester les contrôles de sécurité et vérifier que tous les utilisateurs du système sont des salariés autorisés et qu'il n'existe pas de tentative de pirater le système.

Ainsi, dans une organisation, chaque semaine, un extrait du fichier du journal d'accès au système est envoyé au service de l'audit interne. Les auditeurs extraient l'information sur les identifications et vérifient que chaque utilisateur figure dans le fichier maître actualisé des salariés. Tous les utilisateurs qui ne sont pas des salariés sont repérés et un courrier électron-

ique est automatiquement envoyé au responsable de la sécurité du système afin qu'il annule leurs codes identifiant (ID). Les tests recherchent en outre les tentatives d'entrer dans le système qui ont échoué. Ils ont ainsi détecté qu'à trois heures du matin, un identifiant utilisateur a tenté à 25 reprises, sans succès, d'entrer dans le système via une connexion sur le réseau téléphonique. Les auditeurs ont utilisé ce rapport pour justifier le changement des paramètres d'entrée afin que les codes d'accès utilisateurs soient bloqués après trois tentatives infructueuses d'entrer dans le système.

Les usages possibles de l'évaluation continue des contrôles sont quasiment illimités. Pour chaque exposition au risque, les auditeurs internes peuvent élaborer un test ou une procédure analytique afin de rechercher des preuves montrant que des individus tentent de tirer avantage des failles ou des faiblesses dans les contrôles. Dans certains cas, ces expositions englobent des risques de fraude, de gaspillage ou d'abus. La fréquence et les échéances de ces tests dépendront du risque potentiel pour l'entreprise et de l'adéquation du cadre de contrôle et du pilotage opéré par le management.

Fraudes, gaspillages et abus

Selon la Norme 1210.A2 de l'IIA, « Les auditeurs internes doivent posséder des connaissances suffisantes pour évaluer le risque de fraude ». De plus, d'après la Norme 1210.A3, « Les auditeurs internes doivent posséder une connaissance suffisante des principaux risques et contrôles liés aux technologies de l'information et des techniques d'audit informatisées susceptibles d'être mises en oeuvre dans le cadre des travaux qui leur sont confiés. » Le recours aux technologies facilitant l'évaluation continue des contrôles peut aider les auditeurs à examiner aussi bien les transactions détaillées que les données de synthétise, afin de repérer les anomalies et autres indices de fraude, de gaspillage et d'abus. Par exemple, à l'aide des technologies d'analyse des données, les auditeurs peuvent facilement identifier les cas dans lesquels quelqu'un a outrepassé le pouvoir de conclure des contrats (par exemple en concluant des contrats supérieurs au plafond autorisé) ou contourné ce pouvoir (en scindant les contrats). Dans le domaine de la gestion des payes, ces technologies peuvent servir à repérer les personnes figurant sur la liste des salariés à payer mais pas dans la base de données de salariés, ou à repérer des taux de rémunération inhabituels.

Sachant que la fraude est souvent commise parce que l'occasion se présente, il faut repérer les lacunes et les faiblesses des contrôles et, si possible, les réduire ou les supprimer. Des guides et des normes d'audit largement diffusés traitent directement ces problèmes d'exposition et imposent aux auditeurs de bien connaître les possibilités de fraude afin d'être capables d'en identifier les symptômes. Les auditeurs doivent savoir ce qui risque de se passer, comment et qui peut être impliqué. Le Statement on Auditing Standards (SAS) n° 99 de l'American Institute of Certified Public Accountants (AICPA), « Consideration of Fraud in a Financial Statement Audit », est aussi destiné à aider les auditeurs à détecter les fraudes. Il va plus loin que son prédécesseur, la norme SAS n° 82, car il intègre de nouvelles dispositions :

- organiser des séances de réflexion collective (brainstorming) sur les risques de fraude ;
- insister sur un scepticisme professionnel accru ;
- veiller à ce que le management soit conscient des possibilités de fraude ;
- utiliser divers tests analytiques ;
- détecter les cas où le management outrepasse des contrôles.

Il définit aussi les facteurs de risque de fraude dans les rapports financiers ainsi que de risque de vol et peut servir de modèle pour l'évaluation du risque de rapport financier frauduleux. Les risques soulignés dans la norme SAS n° 99 englobent des facteurs tels que l'environnement managérial, l'environnement concurrentiel et d'affaires ou encore la stabilité opérationnelle et financière.

Conclusions et recommandations

Les techniques d'évaluation continue des contrôles peuvent être analogues à celles utilisées par le management pour effectuer son pilotage continu.

Lorsque les auditeurs internes peuvent s'appuyer sur le pilotage continu exécuté par le management, ils n'ont pas besoin de mettre en œuvre des techniques d'évaluation continue des contrôles aussi détaillées. Ils peuvent alors s'attacher à d'autres procédures afin d'apporter une assurance permanente concernant les processus de pilotage continu engagés par le management.

Cependant, lorsque le pilotage continu n'est pas suffisant, les auditeurs doivent procéder à des tests détaillés et recourir à des techniques d'évaluation continue de l'adéquation des contrôles. Grâce à des techniques analytiques intelligentes, les auditeurs peuvent juger de la qualité du cadre de contrôle interne et apporter une assurance indépendante au comité d'audit et à la direction générale.

L'évaluation continue des contrôles ne doit pas forcément être effectuée en temps réel. La fréquence de l'analyse dépendra du niveau de risque et du degré de pilotage des contrôles mené par le management. Par exemple, il est possible d'analyser les transactions par cartes de paiement une fois par mois seulement, à réception du relevé des transactions envoyé par la société de carte de crédit. La liste des salariés peut être testée une fois par période de paie, juste avant l'émission des virements. Les tests visant à détecter les factures et les paiements en double peuvent être effectués tous les jours. Dans certains cas, un auditeur peut procéder aux tests initiaux puis confier le pilotage permanent au management.

Voici d'autres exemples pratiques pour l'application de l'évaluation continue des contrôles :

- Examen des données des transactions, par exemple en identifiant tous les paiements effectués par carte de crédit supérieurs au plafond de dépense de la carte ou auprès de commerçants non agréés.

- Examen des données synthétiques, par exemple sur le total des frais des titulaires de carte qui dépassent 10 000 dollars, lorsque les titulaires n'appartiennent pas à la division achats.
- Analyse comparative, par exemple du total des heures supplémentaires payées par rapport à celles effectuées par tous les autres salariés occupant un poste de même catégorie et de même niveau, afin de repérer les abus potentiels (heures supplémentaires excessives, non autorisées, etc.).
- Test des totaux par compte du grand livre général, mettant en évidence les comptes dont le montant s'écarte de plus de 25 % de celui de l'exercice précédent, afin de détecter des activités inhabituelles, par exemple une augmentation du nombre des sorties de bilan.

Dans tous les cas, les auditeurs peuvent approfondir rapidement la question afin de découvrir la cause des problèmes et de prendre rapidement et facilement des mesures correctives.

Applications de l'évaluation continue des risques

Si le management a la responsabilité d'élaborer et de tenir à jour un système destiné à identifier et à atténuer le risque, la Norme 2120 de l'IIA précise que l'audit interne doit évaluer l'efficacité des processus de management des risques et contribuer à leur amélioration. La Norme 2010 de l'IIA encourage le responsable de l'audit interne à établir « une planification fondée sur les risques afin de définir des priorités cohérentes avec les objectifs de l'organisation ». Ces deux activités sont liées et les auditeurs peuvent recourir à l'évaluation continue des risques pour identifier et évaluer la variation des niveaux de risque. Ils peuvent ainsi évaluer les activités de réduction des risques mises en œuvre par le management et faciliter l'établissement des objectifs pour chaque audit, ainsi que pour le plan d'audit annuel.

On peut employer l'évaluation continue des risques pour identifier et évaluer le risque sur une base permanente.

On y parvient non seulement en mesurant les transactions par rapport à une valeur butoir, mais aussi en recourant à l'analyse comparative de la totalité des transactions. Avec ce type de comparaisons, les auditeurs peuvent examiner la cohérence d'un processus en mesurant la variabilité de plusieurs dimensions. Dans le domaine de l'exploitation, par exemple, la mesure de la variabilité du nombre de défauts permet de tester la cohérence d'une ligne de production. Plus le nombre de défauts varie, plus on peut craindre que la ligne de production ne fonctionne pas de manière correcte et cohérente. Le même principe peut s'appliquer à la mesure de l'intégrité d'un système financier, évaluée par la variabilité - du nombre et du montant des écritures de régularisation – dans le temps et en comparaison avec celle d'entités similaires. Le concept de variabilité constitue le principal facteur de différentiation entre l'évaluation continue des risques et les modules d'audit intégrés complétés des états des anomalies.

En procédant à une évaluation continue des risques, les responsables de l'audit interne peuvent développer des plans d'audit à un niveau plus stratégique et les ajuster en permanence au gré de l'évolution des profils de risque, afin de

- maintenir un plan d'audit actualisé sur l'année ;
- allouer les ressources d'audit peu nombreuses et très spécialisées aux domaines représentant la plus forte exposition pour l'organisation.

Par ailleurs, l'évaluation continue des risques met en évidence les domaines où les contrôles sont inexistants ou non-opérationnels, ce qui incite les auditeurs internes à évaluer les contrôles en continu.

Ainsi, l'évaluation continue des risques sert non seulement à l'élaboration du plan d'audit, mais aussi aux activités d'évaluation continue des contrôles.

Exemple - sélection des sites audités en fonction des risques

Avec plus de 1 100 points de vente dans tout le pays, le service d'audit interne d'ABC Food a besoin d'une méthode efficiente et efficace pour sélectionner chaque magasin à auditer. Dans le passé, les auditeurs s'efforçaient de rendre visite à chaque magasin au moins une fois par an afin d'effectuer un audit de conformité. Toutefois, ce n'était pas un moyen efficient de traiter les véritables domaines représentant un risque.

Le responsable de l'audit interne a donc besoin d'une solution fiable d'évaluation des risques, sur la base de critères fondés sur des données informatisées, afin d'être en mesure d'apporter une assurance sur l'ensemble des 1 100 points de vente sans avoir à visiter chacun d'eux tous les ans. L'évaluation continue des risques a permis de définir les indicateurs analytiques requis, par exemple les pertes d'inventaire signalées et la rotation des salariés expérimentés. Désormais, l'équipe d'audit interne peut rapidement repérer les points de vente présentant le risque le plus élevé et élaborer une approche d'audit plus rapide, efficace et efficiente.

Élaboration du plan d'audit

Au lieu de planifier les audits selon un cycle standard de rotation sur un, deux ou trois ans, il convient de définir la fréquence des audits en fonction des facteurs de risque dans le processus.

À un niveau supérieur, l'évaluation continue du risque facilite l'élaboration des plans d'audit, en permettant une identification et une évaluation des indicateurs de risque fondées sur des données. Elle facilite à la fois la mise en place de l'univers d'audit et la collecte des données quantitatives, ce qui permet au service d'audit interne de se concentrer sur les risques les plus prioritaires au sein de l'entreprise et de consacrer les ressources nécessaires aux domaines nouveaux ou en mutation.

La première étape consiste à définir le champ et la couverture de l'audit, puis à identifier les mesures et seuils de matérialité ainsi que les indicateurs du risque à l'aide de données

provenant des divers systèmes de l'entreprise :

- systèmes financiers,
- systèmes de ressources humaines,
- systèmes d'informations opérationnelles.

Concernant la matérialité, une méthode consiste à étudier la taille relative de chaque entité, tandis que les indicateurs du risque se baseront sur la complexité de l'entité par rapport aux autres.

L'évaluation continue des risques doit également comprendre un examen des résultats de la fonction de pilotage réalisée par le management, notamment sur les mesures de performances, les contrôles qualité et la séparation des fonctions.

Exemple – Élaboration du plan d'audit

L'élaboration d'un plan d'audit fondé sur le risque chez ABC Corp. a nécessité

- l'instauration d'un univers d'audit et la définition des entités auditées ;
- la collecte et l'analyse des données qualitatives comme les business plans, les organigrammes, les informations fournies par le management ou encore provenant de groupes de travail ;
- la collecte, la normalisation et l'analyse des données quantitatives telles que les informations financières, opérationnelles et relatives aux ressources humaines ;
- le classement des audits (ou des entités auditées) par ordre de priorité sur la base des indicateurs de risque.

Voici comment ABC Corp. a utilisé l'évaluation continue des risques pour le développement de son plan d'audit annuel, dans le but de mesurer et de classer par ordre de priorité le niveau de risque intrinsèque concernant la situation financière, les ressources humaines et la production pour chaque entité auditée.

Mesures et indicateurs financiers – La matérialité des aspects financiers transparaît essentiellement dans les montants des charges, des recettes et des actifs. Ces montants varient considérablement, car, par exemple, toutes les entités auditées ne dégagent pas de recettes ou ne possèdent pas d'actifs. Les indicateurs de complexité prennent en compte non seulement les variations par rapport à l'exercice précédent et la part relative, mais aussi des aspects tels que le nombre des centres de responsabilité, le pourcentage des dépenses discrétionnaires et le fait que l'entité doive ou non gérer ses charges, ses recettes et ses actifs. Par exemple, l'entité A, qui enregistre 15 millions de dollars de charges, essentiellement pour les salaires, ne présenterait pas le même niveau de risque financier que l'entité B, qui affiche 5 millions de dollars de charges (dont 82% de dépenses discrétionnaires), 10 millions de dollars de chiffre d'affaires et 12 millions de dollars d'actifs. En outre, si c'est la première année que l'entité B dégage des recettes, cela élève aussi son niveau de risque financier.

Mesures et indicateurs relatifs aux ressources humaines – La mesure de matérialité relative aux ressources humaines s'exprime par le chiffre des effectifs totaux, alors que la composition du personnel (par exemple salariés ou sous-traitants, à temps plein ou partiel), ainsi que le taux de rotation et la perte des compétences essentielles formeront l'indicateur de complexité. Elle s'intéresse aussi aux variations par rapport aux exercices précédents (une organisation en croissance rapide peut courir des risques différents de ceux d'une organisation stable) et au nombre de sites (c'est-à-dire la dispersion géographique) de l'entité.

Mesures et indicateurs opérationnels – Chez ABC Corp., les mesures et indicateurs opérationnels portent essentiellement sur le nombre de produits, et donc la matérialité y est également liée.

Chez ABC Corp., la complexité résulte non seulement des variations du nombre et de la composition de produits, mais aussi des délais de production, de la réactivité face aux demandes des clients et de la complexité des processus de fabrication.

La complexité de la fabrication y est divisée en trois catégories (faible, moyenne et forte) en fonction de la durée de l'opération. En effet, un produit dont la fabrication dure 20 heures non seulement est plus long à fabriquer, mais entraîne aussi un risque opérationnel supérieur, comparé à un produit dont la fabrication ne durera que deux heures. Le personnel de fabrication a confirmé que cette hypothèse constituait une représentation raisonnable de la complexité.

Une fois que toutes les données des trois systèmes ont été recueillies, normalisées et analysées pour chaque entité auditée, on a calculé le score relatif de chaque entité, en comptant le nombre de fois qu'une entité se situait dans les 10 premières pour les indicateurs de risque concernés. Chaque entité a été classée par rapport à toutes les autres, et non en valeur absolue. Dans la mesure où aucune valeur absolue n'a été utilisée pour aucun attribut, il n'a pas été nécessaire d'ajuster les paramètres à mesure que les performances se sont améliorées.

Étant donné l'évolution rapide de l'environnement d'affaires, il est possible que les plans d'audit annuels ne soient pas assez réactifs à l'évolution du niveau des risques. Cependant, grâce aux activités assistées par ordinateur, il est facile d'actualiser les évaluations des risques et de piloter les indicateurs de risque de manière continue. Il est possible de tester fréquemment les évaluations des risques afin que les audits planifiés traitent bien les risques actuels ou nouveaux. De plus, en comparant les résultats des évaluations des risques sur la durée, les auditeurs peuvent anticiper des expositions au risque avant qu'elles ne deviennent graves. Ces résultats peuvent servir à fixer les paramètres pour l'action d'audit officielle et pour en déterminer le calendrier.

La réaction des auditeurs peut varier en intensité et en urgence selon le niveau de risque. Si le risque est identifié de manière précoce, un audit complet ne sera peut-être pas nécessaire, et un simple courrier décrivant l'exposition au risque et demandant au management de réagir suffira.

Non seulement les ressources d'audit pourront alors se concentrer sur des aspects plus risqués, mais leur efficacité s'en trouvera maximisée.

Soutien aux missions d'audit

L'évaluation continue des risques facilite l'identification et l'évaluation du risque ainsi que l'élaboration du champ et des objectifs de chaque mission d'audit. Elle peut aussi permettre de choisir les sites à visiter et de définir des critères spécifiques (par exemple des axes de vérification).

La différence essentielle entre le recours à l'évaluation continue des risques pour l'élaboration du plan annuel d'audit de l'entreprise et pour le soutien à chaque mission d'audit réside dans le degré d'utilisation des informations détaillées pour identifier et évaluer le risque. Pour le plan annuel d'audit de l'entreprise, des informations synthétiques sur chaque entité suffiront, alors qu'au niveau de chaque audit, des informations plus détaillées sont nécessaires si l'on veut identifier le risque à un niveau qui permettra de définir le champ et les objectifs d'un audit donné.

Dans un audit classique, l'échelle et le périmètre des procédures d'examen analytiques sont limités par le type et le volume des données qui peuvent être collectées via les techniques traditionnelles. L'audit continu peut augmenter le volume et le périmètre des données disponibles pour l'auditeur. Le déploiement des méthodes d'audit continu donne la possibilité d'élargir considérablement la périmètre des procédures analytiques. Ainsi, une fois automatisé, un rapprochement initialement annuel peut être programmé en procédure d'audit continu et être effectué plus fréquemment. Les ratios qui sont calculés lors d'un examen analytique peuvent être intégrés au logiciel d'audit continu et être calculés plus souvent, puis révisés et comparés aux valeurs critiques, ce qui permet de signaler les écarts significatifs.

Exemple – Soutien d'un audit des créances fournisseurs (CF)

Dans le cadre de l'évaluation des risques effectuée pendant la planification d'un audit de la fonction CF, qui se déroulera sur plusieurs sites dans le pays, l'auditeur calcule le volume et le coût par transaction traitée par les services CF, ainsi que le nombre et les qualifications des salariés requis. L'analyse d'ensemble a déterminé que la fonction CF est décentralisée, sans processus standard. De plus, différents bureaux traitent différents types de transactions. Les auditeurs utilisent le « coût par transaction » et le « nombre de transactions par utilisateur » pour évaluer l'impact des diverses opérations de traitement des factures, ce qui fait apparaître des problèmes d'efficience et d'efficacité dans certains bureaux. Ces résultats servent à déterminer quels sont les sites qui devront recevoir la visite des auditeurs.

Lorsque le même audit est effectué sur plusieurs sites ou chaque année, il est possible de procéder à des tests d'audit spécifiques, puis d'en comparer les résultats à ceux d'autres entités ou d'une année sur l'autre. L'évaluation continue des risques peut servir à étudier des risques particuliers, par exemple le risque de mauvaise utilisation des cartes de paiement. Ainsi, lorsqu'il compare des lots de données sur deux ans pour chaque entité afin de déceler des tendances, l'auditeur comprend mieux quelles sont les entités qui progressent le plus. L'évaluation continue des risques peut aussi permettre d'évaluer l'impact de tout changement apporté à un processus lorsque l'on effectue la même analyse d'une année sur l'autre. En outre, il sera facile d'ajouter les données correspondant aux années suivantes afin d'évaluer l'effet de la mise en œuvre des recommandations des auditeurs.

Vérification de la mise en œuvre des recommandations d'audit

En reliant des indicateurs fondés sur les données aux recommandations, les auditeurs peuvent recourir à l'évaluation continue des risques afin de déterminer si leurs recommandations ont été suivies et si elles produisent l'effet escompté de réduction du niveau de risque. En particulier, si l'évaluation continue des risques a servi à identifier et à évaluer le risque dans le cadre de l'élaboration du périmètre et des objectifs de l'audit, il est possible de recourir aux mêmes indicateurs pour évaluer l'impact de la mise en œuvre des recommandations des auditeurs.

Dans l'idéal, chaque audit devrait identifier les indicateurs fondés sur les données pour chaque recommandation. Il serait alors facile de définir un niveau de référence et de comparer les résultats, avant et après la mise en oeuvre de la recommandation. Cependant, les auditeurs devront pour cela trouver les indicateurs appropriés qui peuvent être mesurés par les moyens électroniques. Ces indicateurs peuvent être des variables de substitution de ce qui est mesuré. Par exemple, si un auditeur détermine que le personnel n'est pas motivé, il peut recommander d'améliorer la communication. Il peut se fier au nombre de jours de congés maladie ou de réclamations déposées. Si ces chiffres ne mesurent pas directement la motivation, l'auditeur peut s'en servir d'indicateurs, car ils devraient évoluer si la motivation des salariés augmentait. Des données indiquant le recul du nombre de jours d'arrêt-maladie et de réclamations pourraient ainsi servir à montrer qu'une amélioration de la communication a été engagée et a produit les résultats escomptés.

Exemple – Bons de commande

Un contrôle financier impose que chaque achat de plus de 5 000 dollars fasse référence à un bon de commande. Les auditeurs ont instauré un test d'audit continu examinant toutes les factures de plus de 5 000 dollars afin de valider la référence requise au bon de commande. Au départ, les tests signalent de nombreux cas de non-respect de cette obligation. Les auditeurs recommandent une modification dans les contrôles du système financier. Un mois plus tard, après la mise en place du nouveau contrôle, le test établit que toutes les factures d'un montant supérieur à 5 000 dollars font désormais référence à un bon de commande.

Bien que le test ait indiqué que les contrôles fonctionnent, l'auditeur se demande s'ils fonctionnent correctement. Il procède à un test rapide pour déterminer le montant total des factures faisant référence à un bon de commande et compare ce total au montant des bons de commande. Étant donné que les livrables correspondant à un bon de commande peuvent être acheminés en plusieurs expéditions, certains bons de commande ont donné lieu à plusieurs factures. L'auditeur est toutefois surpris de trouver des bons de commande correspondant à une centaine de factures et des règlements totalisant des centaines de fois le montant du bon de commande initial. L'auditeur en conclut que même si chaque facture de plus de 5 000 dollars fait bien référence à un bon de commande, certains utilisateurs se sont simplement servis du même bon de commande à chaque fois.

Les vérifications après les recommandations de l'auditeur ont porté sur 100 % des transactions de plus de 5 000 dollars. Il est apparu qu'après la formulation de ces recommandations, la mention d'un bon de commande a bien été apposée sur chaque facture, mais elle ne correspondait pas au bon de commande approprié.

Conclusion

L'évaluation continue des risques n'est pas un système statique. La définition des indicateurs et l'évaluation de leur utilisation et de leur intérêt constituent des tâches essentielles. Il convient d'évaluer en continu les risques internes et externes afin de traiter rapidement les risques qui se profilent et que l'organisation puisse réagir à l'évolution de l'environnement. Le responsable de l'audit interne doit veiller à ce que les systèmes de notification appropriés existent afin de procurer un retour d'information sur les risques nouveaux. Il convient de classer par ordre de priorité et de gérer les facteurs de risque en veillant à bien comprendre qui les reçoit, comment ils sont communiqués et quelles sont les mesures à prendre. Par ailleurs, les auditeurs doivent en permanence recevoir un retour d'information sur l'utilité de l'audit continu en évaluant les risques et doivent élaborer des stratégies d'amélioration du processus et de communication des résultats. Le responsable de l'audit interne doit en particulier déterminer comment les résultats de l'audit seront utilisés dans l'activité de management du risque d'entreprise (ERM) effectuée par le management.

La notion d'audit continu n'est pas un concept difficile. Cependant, les auditeurs internes n'y recourent pas à grande échelle et la direction générale n'apprécie pas pleinement le besoin technologique y afférent ni n'apporte les financements requis.

Pour que sa mise en œuvre soit fructueuse, l'audit continu nécessite l'adhésion de tous les acteurs concernés et une approche progressive qui s'adresse en premier lieu aux systèmes les plus critiques de l'entreprise. Même si chaque organisation est différente, il existe un certain nombre d'activités communes qui doivent être soigneusement planifiées et gérées lorsque l'on opte pour l'audit continu (voir « Phases clés » ci-dessous). Le séquencement de ces activités peut varier. De plus, il peut y avoir des activités autres que celles qui sont énumérées ci-dessous, en particulier lorsque l'on développe l'audit continu dans le cadre d'une mission d'audit particulière.

Les objectifs de l'audit continu

Nombre d'organisations envisagent d'introduire l'audit continu pour soutenir l'évaluation des contrôles imposés par des textes tels que la loi Sarbanes-Oxley. La présence d'un système automatisé adéquat pour tester les contrôles contribue à l'évaluation des contrôles internes et à l'impératif global d'amélioration de la qualité de la gouvernance d'entreprise. Il procure aussi des avantages supplémentaires, sous la forme d'une amélioration des performances de l'entreprise qui peut être significative. Il est important que le responsable de l'audit interne tienne compte des objectifs à court et à long terme de l'audit continu. L'effort nécessaire pour accéder aux systèmes et processus clés de l'entreprise et les comprendre peut potentiellement alléger le fardeau que représente la mise en conformité à la réglementation et lever les freins aux améliorations de performance de l'entreprise.

PHASES CLES

Objectifs de l'audit continu

- Définir les objectifs de l'audit continu.
- Obtenir et gérer le soutien de la direction générale.
- Évaluer dans quelle mesure le management remplit son rôle de pilotage.
- Identifier et classer par ordre de priorité les domaines à traiter et les types d'audit continu à réaliser.
- Identifier les systèmes d'information et les sources de données clés.
- Comprendre les processus de l'entreprise et les systèmes applicatifs sous-jacents.
- Développer des relations avec le management des SI.

Acces et utilisation des donnees

- Choisir et acheter des outils d'analyse.
- Développer des capacités d'accès et d'analyse.
- Développer et maintenir la compétence et la technicité y afférente des auditeurs.
- Évaluer l'intégrité et la fiabilité des données.
- Nettoyer et préparer les données.

Evaluation continue des controles

- Identifier les points de contrôle critiques.
- Définir les règles de contrôle.
- Définir les exceptions.
- Élaborer une approche technologique pour tester les contrôles et identifier les déficiences.

Evaluation continue des risques

- Définir les entités à évaluer.
- Identifier les catégories de risques.
- Identifier des indicateurs des risques/de performance fondés sur les données.
- Concevoir des tests analytiques pour mesurer l'accroissement des niveaux de risque.

Communiquer et gerer les resultats

- Classer les résultats par ordre de priorité et déterminer la fréquence des activités d'audit continu.
- Effectuer les tests régulièrement et en temps utile.
- Identifier les déficiences des contrôles ou l'accroissement des niveaux de risque.
- Classer les résultats par ordre de priorité.
- Engager une action appropriée et communiquer les résultats au management.
- Gérer les résultats : repérage, communication, pilotage et suivi a posteriori.
- Évaluer les effets des mesures qui ont été prises.
- Piloter et évaluer l'efficacité du processus d'audit continu, tant l'analyse (par exemple règles/indicateurs) que les résultats obtenus, et modifier les paramètres de test selon les besoins.
- Veiller à garantir la sécurité tout au long du processus d'audit continu et l'existence de relations appropriées avec les initiatives du management (ERM, pilotage et mesure des performances, par exemple).

Il est maintenant temps de cesser de commenter la fiabilité des rapports financiers trimestriels pour adopter un paradigme d'audit continu qui contribue à la santé globale de l'organisation ainsi qu'à son efficience et à son efficacité opérationnelles. En particulier, le service d'audit interne doit s'intéresser aux contrôles portant sur les processus de bout-en-bout (COSO) et les systèmes d'information (COBIT – Control Objectives for Information and Related Technology) présents dans quasiment toutes les activités de l'entreprise.

La fiabilité des systèmes et des données relatives aux transactions est primordiale, non seulement pour le cadre du contrôle interne et pour l'intégrité de la communication financière, mais aussi pour l'efficience des opérations de l'entreprise. Ainsi, le responsable de l'audit interne et la direction générale doivent avoir pour objectif principal de veiller à la fiabilité, à l'intégrité et à la disponibilité des systèmes et des données de l'entreprise. L'audit continu peut aider l'organisation à atteindre cet objectif en facilitant l'évaluation de l'efficacité des contrôles et des niveaux de risques.

Voici une description des étapes nécessaires à la mise en place d'une solution d'audit continu :

Définir les impératifs de l'audit

Pour répondre aux nouveaux objectifs de l'audit, les responsables de l'audit interne doivent comprendre les techniques d'audit continu et les processus d'audit à venir. Les auditeurs internes doivent définir correctement ces impératifs, à l'aide des informations émanant du management et des auditeurs externes. Ils doivent donc comprendre le secteur industriel, l'organisation, les processus, les contrôles y afférents, ainsi que l'usage des solutions informatisées. Cela nécessite d'y consacrer du temps, mais si l'on veut utiliser l'audit continu pour tester les contrôles, identifier et évaluer les risques, détecter et prévenir la fraude, ou pour soutenir d'autres audits, les bénéfices attendus valent bien l'effort demandé.

Obtenir le soutien du management

Une fois que les objectifs de l'audit continu ont été définis, il faut obtenir le soutien du comité d'audit et de la direction générale. Ces derniers doivent non seulement être informés de l'introduction de l'audit continu, mais il faut aussi qu'ils le soutiennent pleinement. Le comité d'audit et la direction générale doivent être informés des prérequis, en particulier des besoins d'accès, ainsi que du mode et du délai de communication des résultats. Sinon, la légitimité de l'audit continu risque d'être remise en question lorsque des anomalies seront identifiées dans les transactions et que les managers seront contactés pour qu'ils fournissent des explications. Quand on lui demandera des explications sur des transactions inhabituelles, la première réaction du manager risque fort d'être la suivante : « Je ne savais pas que quelqu'un avait donné son accord à la conduite d'un audit dans ce domaine. À quel audit est-ce que cela se rapporte ? » Ce type de questions ralentit le processus, car l'auditeur doit expliquer le concept et les objectifs de l'audit continu avant de traiter la faiblesse du contrôle ou le domaine à risque identifiés.

Déterminer le périmètre des tests

L'étape suivante consiste à déterminer le périmètre des tests détaillés que doit effectuer l'audit interne sur les contrôles et les risques. La pertinence des actions et activités de pilotage menées par le management joue un rôle clé à cet égard. Le responsable de l'audit interne doit examiner le cadre de contrôle et les domaines traités par l'ERM. Si le management dispose de processus bien établis et efficaces pour évaluer les contrôles et les risques, alors les auditeurs internes pourront se fier davantage aux niveaux de contrôle et de risques indiqués. Cependant, si le responsable de l'audit interne juge que les processus ne sont pas adaptés, les auditeurs devront nécessairement effectuer leurs propres évaluations détaillées des contrôles et des risques sur une base plus continue.

Identifier les sources d'information

Il faut ensuite identifier l'information requise pour atteindre les objectifs définis et déterminer quelles sont les sources possibles de cette information. Même si cette étape ressemble à celle qui intervient dans tout audit ou toute revue des contrôles, qu'elle soit ou non assistée par ordinateur, les auditeurs doivent éviter de se laisser influencer par d'anciens modes de pensée. Ils doivent comprendre clairement ce qu'ils essaient d'accomplir avant de définir les besoins en information. Il faut ici identifier ce qu'il faut faire, et non la manière de le faire. Celle-ci sera déterminée dans une phase ultérieure.

Négocier l'accès aux données

L'obtention des données correctes constitue un aspect critique de la mise en place de l'audit continu. Le responsable de l'audit interne doit identifier les applications auxquelles le service d'audit demande l'accès et déterminer lesquelles de ces applications sont les plus critiques. Il faut ensuite travailler avec les propriétaires du système afin de négocier les droits d'accès. Une bonne relation de travail avec le management des SI est précieuse, car l'aide de ce dernier est souvent nécessaire, même si les auditeurs sont des experts de l'utilisation des outils d'analyse des données. Trop souvent, la documentation des systèmes hébergeant les données voulues est inexistante ou obsolète, et la seule source d'information sur les ensembles de données est le personnel informatique.

Tous les auditeurs doivent savoir à quel point il importe d'identifier les sources d'informations électroniques à l'intérieur et à l'extérieur de l'entreprise. Ainsi, les auditeurs qui effectuent le travail sur le terrain, dans les succursales de l'entreprise, peuvent découvrir des applications développées par les utilisateurs finals susceptibles de servir dans le cadre de l'audit continu. Les auditeurs doivent trouver, collecter, analyser, interpréter et documenter les sources d'information automatisées afin d'étayer les résultats. L'information recueillie doit être factuelle, attestée par sa source, pertinente et utile afin qu'elle procure un fondement solide aux résultats. Lorsqu'ils cherchent des sources d'information, les auditeurs

doivent commencer par supposer que l'information existe sous forme électronique, et si possible :

- déterminer les sources et les applications informatiques éventuelles ;
- identifier les propriétaires de l'information (les auditeurs peuvent avoir besoin de leur permission avant que le service informatique puisse leur donner accès aux applications ou aux fichiers de données.) ;
- identifier l'informaticien en charge de l'application ;
- obtenir toute la documentation nécessaire : dictionnaire de données, dessins d'enregistrement, descriptif général du système et processus.

Les auditeurs ne doivent pas se limiter au premier système d'information qu'ils découvrent. Une recherche plus approfondie permettra souvent de trouver de meilleures sources ou des sources corroborant l'information requise. Les propriétaires du système et des processus peuvent jouer un rôle inestimable à cet égard. Les discussions avec les propriétaires des données et les équipes informatiques peuvent aider les auditeurs à déterminer quelle est la meilleure source d'information. Ces discussions peuvent aussi permettre d'identifier des domaines clés et d'autres sources de données utiles. Il faut toujours tenir compte des sources de données des antennes locales et du siège. Lorsqu'il existe deux sources de données, la comparaison des données peut se révéler extrêmement précieuse si l'on veut identifier les déficiences des contrôles et les expositions au risque.

Comprendre les processus

Une fois les principales sources de données identifiées, les auditeurs doivent comprendre non seulement les systèmes d'information, mais aussi les processus qu'ils soutiennent. On peut obtenir une compréhension de base à partir de la documentation existante en :

- passant en revue la documentation générale décrivant le système : manuels utilisateur et techniques, diagrammes de flux, copies des documents à traiter, exemples d'états imprimés et descriptions des contrôles du système ;
- interrogeant les utilisateurs et les équipes informatiques des systèmes concernés ;
- interrogeant les gestionnaires des processus ;
- examinant les comptes rendus de traitement et d'anomalies existants.

Pour acquérir une connaissance approfondie du système, on peut par exemple :

- analyser les diagrammes de flux détaillés et/ou leurs descriptifs détaillés ;
- examiner les documents et états en entrée et en sortie ;
- étudier les dessins d'enregistrement de tous les fichiers de données, y compris les descriptions de champs et les explications relatives aux valeurs possibles dans chaque champ ;
- examiner les décomptes de transaction, les rapports d'anomalies et les états récapitulatifs et les comparer à d'autres rapports ou systèmes.

L'intégration de tous les auditeurs dans le processus d'identification des sources d'information possibles peut contribuer à changer la perspective de l'audit, qui passera ainsi du mode de pensée traditionnel et orienté vers le passé à une vision d'avenir, en utilisant l'audit continu comme un outil d'audit global. On obtient ainsi une compréhension détaillée des systèmes clés, des contrôles et des éléments de données essentiels. En outre, les auditeurs doivent disposer de droits d'accès sécurisés et être capables d'effectuer l'extraction, la normalisation et l'analyse des données.

Identifier les principaux contrôles et risques

L'objectif ultime de l'audit continu est de parvenir à l'efficacité de tous les contrôles et de contribuer à réduire les risques.

Dans la pratique, le meilleur moyen consiste à identifier les contrôles et catégories de risques critiques. Comme l'a noté le Public Company Accounting Oversight Board (PCAOB) aux États-Unis, dans ses conseils relatifs à la mise en œuvre de la norme d'audit n° 2, les auditeurs doivent recourir à l'évaluation du risque pour déterminer quels sont les contrôles qui doivent être examinés. Le responsable de l'audit interne doit privilégier les activités qui donneront le retour sur investissement le plus immédiat et le plus conséquent. Les auditeurs ont besoin de s'appuyer sur les réussites qui démontrent la faisabilité et l'utilité de l'audit continu. Par conséquent, il est nécessaire de déterminer l'ordre de priorité des processus et des systèmes qui se prêtent bien à l'audit continu. En définissant les objectifs, le responsable de l'audit interne doit également déterminer les connaissances, les compétences et les disciplines nécessaires pour mener efficacement des missions d'audit continu. En particulier, les auditeurs auront besoin du type et du niveau d'expertise technique requis et d'un accès aux technologies appropriées.

Accès aux données et utilisation des données

Comme dans tout usage d'une technologie, l'audit continu ne se résume pas à ses aspects techniques. Cependant, il est essentiel de sélectionner la technique qui permettra d'obtenir des résultats probants sur le long terme (Voir Continuous Auditing: Potential for Internal Auditors, chapitre 5 – Enabling Technologies, IIARF, 2003, pour une liste des technologies susceptibles de jouer un rôle dans le développement des méthodes d'audit continu). Un ensemble clair d'objectifs pour l'audit continu et un plan visant à déterminer les risques et priorités correspondants permettra d'orienter le choix des logiciels.

Lorsqu'il sélectionne des logiciels pour l'audit continu, le responsable de l'audit interne doit tenir compte des sources de données, des formats et des volumes des transactions. Il doit également examiner l'environnement informatique de

l'entreprise, ainsi que ses prévisions d'évolutions, concernant les systèmes clés. Même si des applications d'audit continu plus sophistiquées peuvent se révéler nécessaires à plus long terme, on peut également profiter de la flexibilité offerte par des logiciels d'audit. Les logiciels d'audit peuvent lire divers types de données, y compris celles émanant des ordinateurs centraux existants, des systèmes client/serveur, des systèmes reposant sur Internet, ou des progiciels de gestion intégrés (ERP – enterprise resource planning), comme SAP, Oracle ou PeopleSoft. Ils peuvent facilement combiner et analyser des données issues de divers systèmes et plateformes.

Il est évident que l'audit continu nécessite un accès aux données. Les services d'audit qui n'ont pas obtenu un accès électronique aux données de leur entreprise n'ont pas d'excuse et perdent du temps. Avec les progrès de la technologie, tant au niveau des matériels que des logiciels, la question de l'accès aux données ne constitue plus un obstacle technique majeur et ne nécessite pas de matériels spécialisés ni l'intervention d'informaticiens.

Bien souvent, les problèmes d'accessibilité proviennent de la réticence du management à autoriser les auditeurs à accéder aux systèmes applicatifs de l'organisation. Le soutien du management est souvent nécessaire pour que les auditeurs obtiennent l'accès physique et logique aux informations requises. La direction générale peut devoir introduire une mention dans la charte d'audit, sur le modèle : « Les auditeurs auront accès à tous les systèmes et toutes les informations nécessaires pour mener à bien leur mission ». Une fois le soutien de la direction acquis, les auditeurs doivent faire en sorte que les propriétaires des données soient bien informés de leurs droits d'accès et des exigences y afférentes. Le responsable de l'audit interne doit aussi veiller à ce que l'accès et l'utilisation des données des systèmes n'aient pas d'incidence négative sur le fonctionnement opérationnel de ces systèmes, et à ce que la technologie utilisée par l'audit soit compatible avec l'environnement informatique de l'entreprise.

Accès aux données

Pour utiliser l'audit continu efficacement (pour effectuer l'analyse permanente et le suivi des résultats), il est nécessaire d'accéder à l'information sous forme électronique. La méthode d'accès dépendra des objectifs fixés pour l'audit continu et doit tenir compte de facteurs tels que les volumes de données, le trafic sur les réseaux, la performance des systèmes etc. Le responsable de l'audit interne devra également s'assurer que les bons droits d'accès ont été accordés. Pour les systèmes en exploitation (sur l'ordinateur central ou les systèmes client/serveur), il est nécessaire de disposer d'un accès en lecture seule, dûment autorisé.

L'audit continu requiert généralement la combinaison de plusieurs démarches pour avoir accès aux donnes, comme, par exemple :

- l'intégration du logiciel d'audit continu dans le système afin de traiter les données en place ;
- l'obtention d'un accès indépendant aux fichiers de données du système, sans utiliser le logiciel de l'application, et extraction et préparation des données en vue de son utilisation par le logiciel d'audit continu ;
- l'obtention de comptes rendus de traitements et de sauvegardes sous forme électronique pour analyse ultérieure ;
- Exécution de requêtes ou génération de rapports à l'aide d'un programme d'édition ;
- l'obtention d'un accès physique et logique au système client et habilitation en tant qu'utilisateur doté d'un droit d'accès en lecture seule.

La combinaison des méthodes d'accès utilisées doit permettre aux auditeurs d'exécuter l'audit continu en temps opportun et d'identifier et de rendre compte des transactions mises en évidence. Elle doit aussi permettre aux auditeurs d'identifier facilement les transactions présentant des paramètres similaires, et d'opérer un suivi sur les transactions repérées et marquées.

Accéder et utiliser des données provenant de quasiment toutes les sources nécessitent de bien comprendre le dessin d'enregistrement. Lorsque l'on accède aux données et les transfère, plusieurs attributs de fichiers sont possibles. Il est important non seulement de comprendre la structure des fichiers de données au niveau macro (par exemple un fichier plat, délimité ou encore relationnel) mais aussi au niveau du champ.

Un dessin d'enregistrement renferme des informations sur la structure des enregistrements et sur les champs qui sont stockés sur un fichier. Il sert de référence lors de la définition des données pour le progiciel d'analyse, car il procure des informations sur les noms des champs, le type des données, la longueur de champ et le nombre de décimales éventuel.

Avant que l'audit continu ne puisse commencer, le fichier de données doit être accessible par l'auditeur, ce qui nécessite souvent de transférer les données depuis le système en exploitation vers l'ordinateur de l'auditeur. Aujourd'hui, il existe de nombreuses méthodes pour effectuer ce transfert. En discutant avec les propriétaires des systèmes, les auditeurs pourront plus facilement déterminer la méthode et le format de fichier de données qui sont les plus adaptés à l'audit continu.

Renforcer le savoir-faire et les connaissances des auditeurs

La Norme 1210 de l'IIA stipule que « Les auditeurs internes doivent posséder les connaissances, le savoir-faire et les autres compétences nécessaires à l'exercice de leurs responsabilités individuelles. ». Selon le premier GTAG, qui portait sur les contrôles du système d'information : « Dans une organisation, différents niveaux de connaissances informatiques sont nécessaires pour élaborer une approche systématique et méthodique permettant d'évaluer et d'améliorer l'efficacité des processus de gestion du risque, de contrôle et de gouvernance.

Pour que l'auditeur se montre efficace à tous les niveaux, il est essentiel qu'il sache de quelle façon les SI sont utilisés, quels risques ils induisent et comment il peut y recourir dans son propre travail » .[5]

Le rapport de recherche sur l'audit continu élaboré par l'Institut canadien des comptables agréés (ICCA) et l'American Institute of Certified Public Accountants (AICPA) fait également observer que tous les auditeurs doivent impérativement posséder une bonne maîtrise des SI et de l'objet de l'audit. Ainsi, le service d'audit doit disposer de personnel compétent ayant reçu une formation adéquate qu'il peut affecter spécifiquement aux missions d'audit continu. En particulier, les auditeurs qui développent et maintiennent les applications d'audit continu devront posséder une connaissance approfondie des systèmes auxquels ils ont accès, ainsi que des systèmes et fonctions sous-jacents qui sont à l'origine des transactions étudiées.

Lors de la phase initiale, il est possible qu'en raison de la sensibilité des paramètres, de la robustesse des analyses et d'autres facteurs, l'audit continu repère et marque un grand nombre de transactions. Il faut s'y attendre. La charge de travail nécessaire au suivi des résultats décroitra à mesure que les contrôles seront améliorés, les indicateurs analytiques affinés et que l'audit continu évoluera.

Les résultats préliminaires de l'audit continu peuvent également contenir des erreurs d'interprétation des données ou des résultats. Cela s'explique souvent par un manque de compréhension ou de familiarité avec les systèmes et la nature des tests effectués. Les auditeurs doivent parfaitement comprendre le système d'information et les données concernés. Pour que l'audit continu porte ses fruits, il est essentiel de comprendre les données examinées avant de communiquer les résultats. Si l'auditeur ne comprend pas ce que les données représentent, il tirera inévitablement des conclusions erronées, qui ne sauront identifier les faiblesses critiques des contrôles ou en trouveront alors qu'il n'y en a pas. Le temps et les efforts consacrés à développer et comprendre les données (et à veiller à ce qu'elles soient exactes et complètes) aideront les auditeurs à rendre une analyse précise. Pour ce faire, on pourra :

- examiner les champs et éléments de données clés ;
- examiner les méta-données dérivées des fonctionnalités de traitement des données ;
- déterminer le degré d'actualité des données. (L'information est-elle actuelle ? À quelle fréquence est-elle mise à jour ? De quand date la dernière mise à jour ?) ;
- déterminer si l'information est complète et exacte ;
- vérifier les hypothèses et l'analyse de l'auditeur auprès des équipes informatiques concernées ;
- vérifier l'intégrité des donnés en effectuant divers tests : contrôles de vraisemblance, contrôles des états de sortie, comparaison avec d'autres sources, y compris des enquêtes et rapports d'audit antérieurs (intégrité syntactique, sémantique et pragmatique des données).

Étant donné que tous les auditeurs constituent une source d'information potentielle sur les applications locales et de l'entreprise, la communication joue un rôle critique dans la compréhension des sources d'information. Les connaissances acquises par les canaux, notamment informels, doivent également être communiquées. Les services d'audit doivent développer des mécanismes, tels que l'usage d'intranets ou de collecticiels, qui donnent à tous les auditeurs un accès aux systèmes d'information et à la documentation y afférente.

Veiller à l'intégrité des données

L'intégrité des données est extrêmement importante pour que les techniques d'audit continu puissent être correctement appliquées. Les auditeurs doivent veiller à l'intégrité non seulement de leur analyse, mais aussi des données et de leur interprétation des résultats. Pour commencer, ils devront évaluer l'intégrité des données du système. Mais comment faire et jusqu'où aller ? Comment trouver le bon équilibre entre trop (sur-vérification) et pas assez (sous-vérification) ? On trouvera la réponse à ces questions en évaluant les conséquences que peut avoir l'utilisation de résultats erronés et en déterminant la quantité de tests et de vérifications nécessaires pour ramener le risque d'audit à un niveau acceptable.

Comment utiliser les données ?

Une fois que les auditeurs ont identifié les systèmes clés, accédé aux données et vérifié leur intégrité, ils doivent réfléchir à l'utilisation qui sera faite de ces données. L'audit continu est en mesure d'extraire des données de plusieurs systèmes présents au sein de l'organisation et de combiner ces informations en vue d'une analyse inter-systèmes plus poussée. Ainsi, une organisation peut avoir mis en place un contrôle imposant que tous les achats d'un montant supérieur à 5 000 dollars fassent référence à un bon de commande. Or, les données relatives aux achats et au règlement des factures se trouvent dans des systèmes distincts. Le système d'audit continu pourrait tester ce contrôle en regroupant les données relatives aux achats et au règlement des factures afin d'identifier les factures portant sur des montants supérieurs à 5 000 dollars qui ne correspondent pas à un bon de commande. La combinaison de données émanant de divers systèmes nécessite souvent de nettoyer les données afin d'éliminer les transactions présentant des problèmes d'intégrité, d'en modifier le format, etc. Les logiciels d'audit conviennent particulièrement bien au nettoyage des données émanant de différents systèmes et permettent d'en faciliter l'utilisation. Ainsi, si un système saisit les numéros d'identification des salariés dans le format xxx-xxxxxx et l'autre dans le format xx-xxxx-xxx, le logiciel

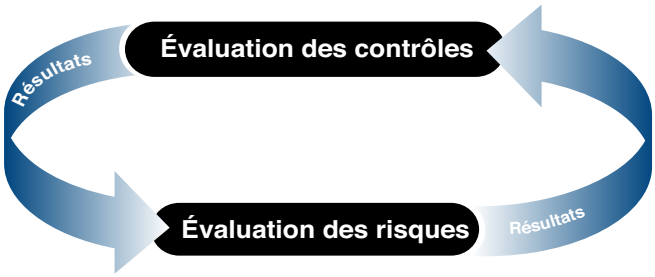
[5] *GTAG : Les contrôles du système d'information*, IIA, mars 2005.

d'audit est capable d'établir rapidement un format commun.

Relation entre évaluation continue des contrôles et des risques

La libre circulation de l'information dans les deux sens constitue un ingrédient clé du continuum contrôles/risque. Les auditeurs qui évaluent le risque en continu ne doivent pas uniquement contribuer aux activités d'ERM du management, mais aussi utiliser les résultats de l'évaluation des risques comme données d'entrée dans l'évaluation continue des contrôles. Selon la norme de l'IIA, l'audit interne doit évaluer la pertinence et l'efficacité du dispositif de contrôle permettant de couvrir les risques relatifs au gouvernement d'entreprise, aux opérations et systèmes d'information de l'organisation.

Il n'est pas surprenant qu'un niveau accru de risque signale l'inefficience ou l'absence de contrôle. À l'inverse, les défaillances des contrôles identifiées doivent être prises en compte lors de l'examen des niveaux de risque. Cela n'implique pas qu'un niveau de risque accru nécessite des contrôles supplémentaires ou que les faiblesses des contrôles produisent nécessairement un risque accru. Cependant, les résultats de l'évaluation de l'un doivent constituer les données d'entrée dans l'évaluation de l'autre.



L'audit interne et le responsable de l'audit interne peuvent créer une valeur ajoutée importante en :

- examinant les systèmes de contrôle et processus de gestion des risques les plus critiques ;
- évaluant l'efficacité des évaluations des risques et des contrôles internes de la responsabilité du management ;
- donnant des conseils concernant la conception du cadre de contrôle et les stratégies de réduction des risques, ainsi que les améliorations à y apporter.

Évaluation continue des contrôles

On ne soulignera jamais assez l'importance des contrôles pour la communication financière et les processus opérationnels. L'intégrité de ces derniers s'appuie sur la conformité, l'efficacité et l'efficience des contrôles. Ceux-ci doivent aboutir à la confidentialité, l'intégrité, la disponibilité et la fiabilité de l'information. Les auditeurs doivent être de plus en plus vigilants lorsqu'ils évaluent les contrôles en continu afin d'en attester l'efficacité.

L'évaluation continue des contrôles procure une analyse indépendante des données transactionnelles via des tests prédéterminés. Ces tests reposent généralement sur le cadre du COSO. L'évaluation continue des contrôles permet au responsable de l'audit interne d'avertir le management rapidement des violations ou des défaillances des contrôles.

L'évaluation continue des contrôles ne se borne pas à repérer des exceptions simples, telles que des valeurs qui dépassent un seuil (ex : transactions par carte de paiement supérieures à 10 000 dollars) ou des cas où l'information requise est manquante (ex : aucune référence à un bon de commande). Ce sont des symptômes connus et un système d'évaluation continue des contrôles peut facilement les repérer.

Le véritable atout de l'évaluation continue des contrôles réside dans sa capacité à effectuer des tests de contrôles plus complexes et sophistiqués. Ces tests peuvent utiliser :

- des transactions détaillées (ex : autorisation accordée par un utilisateur ne disposant pas d'un pouvoir suffisant pour ce type de transaction, ou versements effectués à un fournisseur ayant le même nom que l'utilisateur autorisant la transaction) ;
- la totalité des transactions (ex : factures présentant plus de deux écarts types à la moyenne).

L'évaluation continue des contrôles permet aussi de repérer des exceptions qui se manifestent sous forme d'anomalies. Par exemple :

- des fournisseurs n'ayant qu'une facture pour le trimestre ;
- un montant contractuel supérieur aux prévisions, se chiffrant à 49 000 dollars, et qui évite les contrôles sur les contrats de plus de 50 000 dollars (identifiés par une analyse recourant à la loi de Benford) ;
- les cas où un seul utilisateur traite tous les contrats avec un fournisseur donné et présente les mêmes adresses que ce fournisseur.

Les auditeurs doivent examiner l'environnement opérationnel et ses contrôles internes afin de déterminer à quel point les faiblesses et les défaillances exposent l'entreprise au risque. Le système de contrôles internes doit être évalué et testé pour s'assurer qu'il fonctionne comme prévu. Les processus, les points de contrôle, les acteurs clé et les risques doivent être examinés avec attention.

Identification des objectifs de contrôle

Mais par où commencer ? On peut s'appuyer sur le COSO ou le COBIT. Le mieux est de commencer par repérer les contrôles clés. Au départ, le management, épaulé par le service d'audit interne, doit identifier les principales activités et leurs sous-processus, puis déterminer les objectifs de contrôle y afférents. Les objectifs de contrôle peuvent être classés dans les rubriques du COSO : autorisation, précision, exhaustivité, validité, efficience et efficacité, séparation des fonctions et conformité à la réglementation. Par exemple, les processus qui accompagnent les demandes d'achat sont : créer, éditer,

commander et ajuster.

Identification des contrôles clés
L'évaluation continue des contrôles commence par l'identification des contrôles qui portent sur les processus clés. Les auditeurs et le management doivent veiller à l'évaluation des contrôles pour une utilisation efficiente et efficace des ressources de l'entreprise. Des contrôles solides forment une part essentielle de toute stratégie de défense face à la fraude, au gaspillage et aux abus, mais il se peut qu'ils ne fonctionnent pas comme prévu ou qu'ils ne soient plus adaptés. La réorganisation, la réingénierie ou le 'downsizing' peuvent affaiblir fortement, voire annihiler, les contrôles, tandis que l'implantation de nouveaux systèmes informatiques peut offrir des occasions supplémentaires de commettre ou de dissimuler une fraude. Par ailleurs, les auditeurs et le management ne doivent jamais oublier que les contrôles contrôle obligatoires existants peuvent être mal exécutés ou se révéler non pertinents.

Définition des indicateurs analytiques appropriés
Une fois les principaux processus, sous-processus et objectifs de contrôle y afférents définis, les auditeurs internes doivent les classer afin d'identifier les points de contrôle critiques (rapport impact/risque le plus élevé). L'étape suivante consiste à définir des indicateurs analytiques appropriés pour chaque objectif de contrôle. Il faut répondre à une question simple : « À quoi ressembleraient les données si l'objectif de contrôle n'était pas rempli ? » Des tests peuvent alors être développés afin de rechercher les symptômes des expositions au risque. Ainsi, si l'objectif de contrôle précise que les demandes d'achat doivent obtenir une autorisation en bonne et due forme et respecter certaines limites, on peut développer des tests destinés à déceler les demandes non autorisées, les demandes autorisées par des personnes qui ne disposent pas de l'autorité de le faire et les demandes d'achat qui ont été scindées en deux ou plus afin d'éviter les plafonds de dépenses autorisés.

Évaluation continue des risques

La gestion des risques cherche à aligner les stratégies, les processus, les technologies et le savoir de l'organisation afin d'améliorer sa capacité à évaluer et à gérer les incertitudes susceptibles d'avoir une incidence sur sa capacité à remplir ses objectifs. En tant que telle, la gestion des risques est une fonction essentielle du management. Cependant, la norme IIA 2120 établit que les audits doivent évaluer l'efficience des processus de gestion des risques et contribuer à leur l'amélioration. Selon cette même norme, le plan d'audit doit être élaboré à partir de l'évaluation des risques.

Évaluer le cadre de management des risques d'entreprise (ERM)
Afin de pouvoir développer l'évaluation continue des risque, les auditeurs doivent tout d'abord déterminer si le management a mis en place une fonction ERM. Si tel est le cas, ils peuvent commencer par examiner la pertinence des activités de management des risques. Si l'ERM n'est pas correctement mis en oeuvre, l'évaluation continue des risques devra partir de zéro, être plus robuste et menée plus fréquemment par le service d'audit interne. Pour commencer, il peut être utile de se reporter au document *Enterprise Risk Management – Integrated Framework* (Le management des risques de l'entreprise – cadre de référence) du COSO.

Comprendre les domaines de risque potentiel
Pour identifier et évaluer les niveaux de risques, les auditeurs doivent comprendre la mission, les objectifs clés et les sous-objectifs de l'organisation. En outre, ils doivent savoir ce qui peut arriver, et quand, à l'organisation dans le cadre normal de ses activités, ou en conséquence d'un événement inhabituel. Le responsable de l'audit interne doit se tenir informé des événements qui surviennent dans l'environnement interne et externe et qui sont susceptibles d'empêcher l'organisation d'atteindre ses objectifs. Les auditeurs doivent non seulement connaître les domaines dans lesquels leur organisation pourrait être exposée au risque, mais aussi les conséquences potentielles de cette exposition

Étudier les types de risques et leurs conséquences
Il convient ensuite de considérer les catégories de risques ou types d'expositions. Voici les principales catégories de risques :

- Environnement externe.
- Juridique.
- Réglementaire.
- Gouvernance.
- Stratégique.
- Opérationnel.
- Information.
- Ressources humaines.
- Financier.
- Technologique.

Les catégories de risques aident à identifier et à évaluer les risques. Les risques mal gérés ou qui ne sont pas réduits exposent l'organisation. L'identification des catégories de risque aidera les auditeurs à déterminer où des événements potentiels pourraient entraver la réalisation des objectifs.

Identifier les conséquences de l'exposition aux risques
Il convient ensuite d'identifier les conséquences de l'exposition aux risques : perte pécuniaire ou vol d'actifs, perte de données internes ou d'avantage concurrentiel ? Mais, même si les auditeurs parviennent à identifier toutes les expositions au risque possibles, les ressources seront certainement insuffisantes pour les traiter intégralement. Pour focaliser l'attention de l'Audit à bon escient, les auditeurs ne doivent pas simplement identifier et évaluer les risques, mais ils doivent aussi comprendre l'appétence pour le risque de l'organisation et être capables de classer les risques identifiés par ordre de priorité.

Évaluer le niveau de risque
Une fois les expositions aux risques repérées, il est important d'évaluer le niveau de risque. La vraisemblance et la grav-

ité sont deux mesures de risque usuelles. La vraisemblance mesure la certitude que l'exposition se soldera par une perte. La gravité est le degré d'impact du risque s'il se concrétise. L'évaluation des risques doit également examiner les contrôles en place pour réduire ces risques.

Collecter et analyser les données

La dernière étape de l'évaluation continue des risques porte sur la collecte et l'analyse des données qui supportent les processus clé et les domaines les plus risqués pour l'entreprise. Bien souvent, pour identifier, évaluer et contrer les risques, il faut obtenir des renseignements de nombreux niveaux hiérarchiques. Les propriétaires de l'activité et les professionnels des SI aident les auditeurs à développer des indicateurs des risques fondés sur les données. Ces indicateurs doivent réagir aux changements du niveau de risques et être faciles à mesurer.

Les résultats de l'évaluation continue des risques contribuent à la fiabilité du plan d'audit, et parfois à l'ajout d'une mission d'audit. Ils peuvent aussi se révéler utiles lorsque l'on définit le périmètre et les objectifs d'un audit individuel et peuvent être communiqués au management pour information et pour attirer son attention.

Gérer et communiquer les résultats

Lorsqu'il définit le calendrier, le périmètre et l'objet des tests d'audit continu, le responsable de l'audit interne doit tenir compte des objectifs de l'audit continu, de l'appétence pour le risque de l'organisation, du niveau et de la nature du pilotage exercé par la direction et des activités risquées de l'entreprise. Dans certains cas, les auditeurs doivent donner un ordre de priorité aux risques et sélectionner uniquement quelques domaines à risque ou points de contrôle clés pour la première mise en œuvre de l'audit continu.

L'étape suivante consiste à définir la fréquence des tests d'audit continu.

Cette fréquence ira d'un examen en temps réel, ou en quasi-temps réel, de transactions détaillées à une analyse périodique de transactions détaillées, de prises d'empreinte (snapshot) ou de données de synthèses. La fréquence des tests dépendra non seulement du niveau de risque associé au système ou au processus examiné, mais aussi de la pertinence du pilotage réalisé par le management. Les systèmes critiques dotés de contrôles clés pourront faire l'objet d'analyse en temps réel de leurs données transactionnelles. Pour la paye, on peut procéder à des tests d'audit continu juste avant d'émettre les paiements (en fonction de leur périodicité d'émission). Les tests sur les transactions par carte de paiement peuvent être réalisés sur une base mensuelle, lorsque les relevés y afférents ont été envoyés par la société de cartes de crédit. Les évaluations des risques destinées à soutenir le plan d'audit annuel peuvent être effectuées tous les trimestres, tandis que celles relatives à des mission d'audit et au suivi des recommandations peuvent être réalisées quotidiennement.

Il n'y a pas de réponse simple à la question de la fréquence des tests d'audit continu, si ce n'est qu'il vaut mieux en faire souvent que rarement. Lorsque l'on aborde la question de la fréquence, il convient de tenir compte d'un aspect important : l'automatisation des tests d'audit continu abaisse le coût des évaluations des risques et de la vérification des contrôles. Ainsi, examiner 200 factures manuellement prendra deux fois plus de temps que d'en examiner 100. Il est facile de modifier le nombre et la fréquence des tests entièrement automatisés, de manière à ce que la fréquence des opérations ou le volume des transactions considérées n'entraîne pas d'augmentation de la charge de travail ou du coût. Étant donné que c'est le logiciel d'audit continu qui effectue l'analyse, l'examen d'un million de transactions chaque semaine ne représente pas plus de travail que l'examen d'un millier tous les trimestres.

Enfin, lorsqu'il cherche à déterminer où et quand déployer des activités d'audit continu, le responsable de l'audit interne doit tenir compte non seulement des obligations règlementaires, mais aussi de l'ampleur des mesures prises par le management pour réduire le risque et son impact ainsi que leurs conséquences potentielles. Lorsque le management a mis en place des systèmes de pilotage pour les contrôles, les auditeurs internes et externes peuvent en tenir compte et décider du degré de confiance qu'ils peuvent accorder aux processus de pilotage continu pour alléger les tests détaillés sur les contrôles. Pour pouvoir se fier à ces processus, les auditeurs doivent tenir compte des éléments suivants et les évaluer :

- Identification des contrôles internes spécifiques concernés.
- Sécurité de l'accès au système de pilotage.
- Traitement des anomalies de contrôle identifiées.
- Rapprochements avec les totaux de contrôle.
- Journaux des activités de traitement.
- Journaux des changements apportés aux paramètres et seuils des tests.

Une fois les tests effectués, le responsable de l'audit interne peut examiner les résultats afin de repérer les problèmes. Les faiblesses du contrôle sont mises en évidence grâce aux transactions qui échouent aux tests. L'accroissement des niveaux de risque peut être identifié grâce à l'analyse comparative (comparaison d'un processus aux autres processus, d'une entité à d'autres entités ou exécution des mêmes tests et comparaison des résultats sur la durée).

D'un point de vue pratique, lorsque l'on met en place un système d'audit ou de pilotage continu, il faut particulièrement veiller à l'efficience du traitement des cas d'exceptions du contrôle et des risques identifiés. Au moment où un tel système d'audit ou de pilotage continus est introduit, il n'est pas rare qu'un grand nombre d'exceptions soient identifiées qui, après vérification, se révèlent anodines. Le système d'audit continu doit permettre l'ajustement des paramètres de test de manière que, le cas échéant, ces exceptions ne produisent plus d'alertes ou de notifications. Une fois que ces « faux positifs » ont été identifiés, on peut être certain que le sys-

tème ne repérera que les déficiences de contrôle ou les risques qui posent véritablement problème.

En outre, la nature de la réaction de l'audit aux transactions identifiées sera variable, et toutes ne nécessiteront pas un audit ou une action immédiate. Les résultats doivent être classés par ordre de priorité et les actions décidées en conséquence. Il faudra tenir compte des aspects suivants :

- les résultats obtenus ;
- les décisions concernant l'action à mener ;
- qui a été informé et quand ;
- la date prévue de la mesure corrective.

Si une transaction a été signalée au management, l'auditeur doit alors demander à celui-ci de lui fournir une description du plan d'action et l'échéancier correspondant. Une fois que l'action appropriée a été menée, l'auditeur doit réeffectuer le test d'audit continu pour vérifier si la mesure corrective a remédié à la faiblesse de contrôle ou réduit le niveau de risque. Le même problème ne devra plus être mis en évidence par les tests ultérieurs.

Il est vital que tout le monde comprenne bien la logique de l'audit continu. Il est tout aussi important de s'efforcer d'obtenir des indicateurs qui ne puissent pas être manipulés. Le responsable de l'audit interne doit comprendre et prendre des mesures afin d'éviter la manipulation, la mauvaise appréciation et le sur détail de l'analyse (« paralysis by analysis »). L'essentiel est de veiller à ce que les indicateurs tiennent compte de l'évolution des risques et des contrôles, soient facilement compréhensibles de tous les acteurs concernés, protégés de toute manipulation directe ou indirecte, sans modification de leur comportement sous-jacent, et axés sur les objectifs à court et à long terme de l'organisation.

Dans le cadre d'un système d'audit continu, il convient de tenir compte de divers aspects de la sécurité et des contrôles. La question habituelle de la confidentialité de certaines informations s'applique, et l'accès aux résultats de l'audit ou du processus de pilotage doit être restreint et correctement contrôlé. Un autre aspect important de sécurité et des contrôles concerne la détermination des seuils et des paramètres variables des test. Si l'on veut que les résultats de l'audit continu soient fiables, il faut que des contrôles efficaces, y compris des pistes d'audit, soient en place sur les changements effectués. Comme pour toute application des techniques d'audit assisté par ordinateur (TAAO), il importe également de vérifier la concordance des totaux de contrôle émanant des systèmes de données source avec les totaux des transactions testées. Enfin, comme les tests d'audit continu peuvent aussi bien identifier des fraudes que des faiblesses des contrôles et des expositions aux risques, le responsable de l'audit interne doit veiller à ce que les paramètres de test et les résultats soient protégés contre les accès non autorisés.

L'utilisation d'une application d'audit continu bien conçue aidera le service d'audit à donner l'assurance que le management a bien mis en place un cadre de contrôle efficace et gère activement le risque. Cependant, l'audit continu doit rester flexible et réactif aux changements qui interviennent au niveau des expositions et de l'environnement de contrôle. On ne peut pas se contenter de le mettre en place et ne plus s'en occuper pendant des mois. Le responsable de l'audit interne doit régulièrement examiner l'efficience et l'efficacité du programme d'audit continu. Il peut devoir ajouter de nouveaux points de contrôle ou de nouvelles expositions au risque, et d'en supprimer d'autres. Il peut devoir renforcer, ou assouplir, les seuils ainsi que les tests et paramètres de contrôle des différents indicateurs analytiques. Le responsable de l'audit interne doit aussi veiller à ce que les résultats de l'audit continu soient intégrés dans d'autres activités du management (ERM, tableau de bord équilibré, mesure et pilotage des performances).

Obstacles à surmonter et autres considérations

Conditions préalables

Même si l'informatique rend les données plus faciles d'accès qu'auparavant, et que la puissance de calcul rend l'analyse en temps réel de plus en plus aisée, des obstacles techniques demeurent :

- L'information à auditer doit être générée par des systèmes fiables.
- Le processus d'audit continu doit être fortement automatisé et comporter un lien effectif entre le système de l'auditeur et celui de l'entité auditée.
- Des rapports d'audit continu compréhensibles et précis doivent être élaborés et disponibles rapidement.
- Les auditeurs doivent posséder les compétences requises pour mener ce type de missions.

Pour surmonter ces problèmes, les auditeurs doivent pourvoir :

- Accéder aux données pertinentes en temps utile et être capables de normaliser des données provenant de systèmes disparates de l'ensemble de l'organisation.
- Analyser de gros volumes de données sans porter atteinte aux performances opérationnelles du système.
- Comprendre suffisamment les processus pour pouvoir définir les indicateurs analytiques appropriés et identifier les risques potentiels et les points de contrôle clés.
- Identifier la source de données la plus efficace et les points de contrôle sur lesquels mener les tests et analyses de l'audit continu.
- Effectuer un ensemble complet de tests et d'analyses pour vérifier les principaux points de contrôle et domaines à risques et communiquer les résultats en temps opportun.
- Comprendre la nature du test ou de l'analyse lorsqu'on enquête sur les exceptions ou les processus

et systèmes identifiés comme présentant un risque (c'est-à-dire répond au pourquoi investiguer tel système ou tel processus).
- Quantifier le total des expositions au risque.
- Piloter et modifier les variables utilisées pour l'audit continu, régler le système afin qu'il produise des résultats gérables.
- Calibrer les coûts et les efforts en fonction de l'exposition au risque.
- Classer les actions par ordre de priorité.
- Gérer les notifications d'alerte.
- Sécuriser l'accès au système d'audit continu afin d'éviter que des changements non autorisés ne soient introduits dans les travaux d'analyse ou les valeurs de seuil/valeurs butoir.

Accès aux informations personnelles

Même si, dans de nombreux pays, la législation sur le respect de la vie privée permet aux auditeurs internes d'accéder aux informations personnelles à des fins d'audit, l'accès aux informations personnelles des salariés peut constituer un problème important et doit être résolu au début du processus d'audit continu. Pour répondre aux exigences de la législation, on peut demander à l'auditeur de préciser qui aura accès à l'information et comment celle-ci sera utilisée, stockée et protégée.

Étant donné les défis qui se posent actuellement, il est impératif que les responsables de l'audit interne trouvent de nouvelles manières de permettre au service d'audit interne de répondre efficacement aux impératifs d'un environnement qui évolue rapidement et au carcan des exigences réglementaires croissantes. L'approche intégrée de l'audit et du pilotage continus, qui s'appuie sur la technologie informatique, constitue la clé d'une solution viable, rentable et efficiente du point de vue des ressources.

Ces défis peuvent être considérés comme une opportunité pour l'audit interne et ses responsables qui peuvent créer une valeur ajoutée considérable pour l'organisation. L'audit interne se trouve dans une position unique non seulement pour donner à l'organisation l'assurance qu'elle respecte les lois et règlements, mais aussi pour l'aider à renforcer l'efficacité et l'efficience de ses processus. La mise en œuvre de l'audit continu améliorera le résultat net de l'organisation, grâce à une identification rapide des erreurs et des fraudes, ainsi qu'à la création d'un environnement de contrôle interne plus solide dans toute l'entreprise.

Même si l'audit continu peut être utilisé dans toutes les parties de l'organisation, nous prendrons ici un exemple simple, celui des créances fournisseurs (CF), car il fait bien apparaître les points forts de cette approche lorsqu'elle s'applique à une mission d'audit en particulier. Dans l'exemple, on suppose qu'il existe de nombreux centres de traitement des CF distincts, de tailles différentes et remplissant les mêmes fonctions. Cet exemple servira à illustrer quatre grands objectifs :

- Identification et évaluation du risque lié aux processus CF.
- Identification des tendances concernant la performance et l'efficience.
- Identification des défaillances des contrôles, des anomalies spécifiques et des fraudes potentielles.
- Suivi de la mise en œuvre des recommandations de l'audit et de leurs conséquences sur les opérations CF.

Dans chaque cas, l'analyse s'intéresse aux tendances sur la durée et compare l'unité ou la section des CF sur laquelle porte la revue à d'autres groupes de CF au sein de l'organisation. La comparaison par rapport à des centres ou fonctions CF externes ajouterait une dimension supplémentaire à l'examen.

Identification et évaluation des risques

Une grande diversité de facteurs de risque, transparaissant ou non dans les données, doivent être inclus dans la première évaluation des risques. Une évaluation complète des performances repose sur des mesures de coût, de qualité et de rapidité.

- Les mesures relatives au coût couvrent l'aspect financier des performances (par exemple le coût de main-d'œuvre pour les CF).
- Les mesures relatives à la qualité évaluent comment les produits et les services d'une organisation répondent aux besoins des clients (par exemple le nombre moyen d'erreurs par facture).
- Les mesures relatives aux délais sont axées sur l'efficience du processus (par exemple le nombre moyen de jours nécessaires au règlement d'une facture).

Il est également possible de déterminer, pour chaque section de CF, le type de transactions et leur montant. On peut par exemple observer le nombre de corrections apportées aux entrées dans le journal et aux chèques rédigés manuellement. Ce sont des indicateurs de la charge de travail additionnelle. L'analyse dira également combien de types de transactions différents sont traités. Généralement, la complexité des opérations s'accroît avec le nombre de types de transactions traitées.

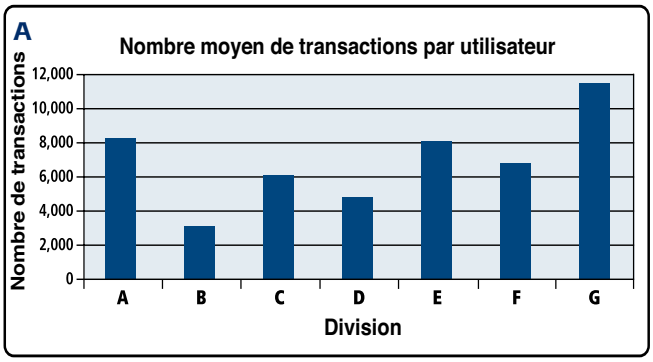
Il est également possible d'examiner les composantes de la structure organisationnelle comme, par exemple, qui rend compte à qui, le nombre et classification/niveau du personnel, l'ancienneté dans un poste, le taux de conservation des effectifs et la formation reçue. Ces données doivent pouvoir être fournies par les ressources humaines. La combinaison de ces informations avec les types et les volumes de transactions peuvent contribuer à identifier les domaines à risques comme, par exemple, du personnel en nombre insuffisant ou pas assez compétent pour traiter des types de transactions complexes.

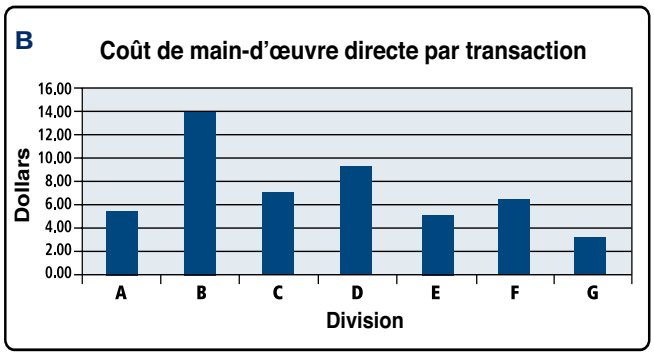
Tendances de la performance et de l'efficience

Lorsque l'on étudie les créances fournisseurs, les données de tendance permettent facilement d'identifier les problèmes de performance et d'efficience. Ainsi, pour chaque opération sur les CF, l'audit continu peut déterminer :

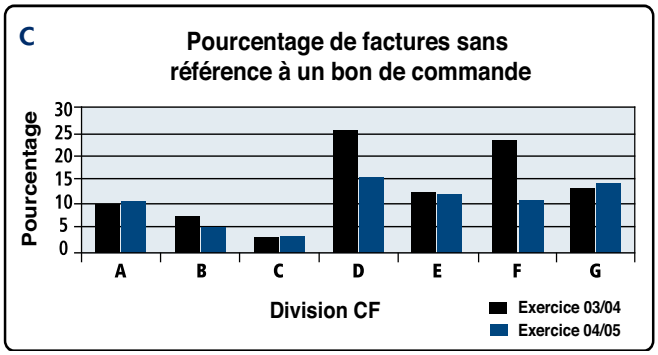
- le nombre et la classification/le niveau du personnel CF ;
- le nombre de factures traitées par chaque utilisateur à chaque extrémité du spectre (un nombre de factures trop élevé ou trop faible peut accroître le risque) ;
- le coût moyen du traitement d'une facture ;
- le nombre moyen de jours nécessaires au traitement d'un paiement ;
- le pourcentage de factures réglées en retard et en avance (cela peut-être particulièrement révélateur si l'entreprise n'obtient pas de remise pour paiements à l'avance) ;
- le pourcentage d'entrées corrigées ;
- le pourcentage de paiements récurrents ou de paiements par virement (transfert électronique de fonds) ;
- le pourcentage de chèques rédigés manuellement ;
- le pourcentage de factures qui ne font pas référence à un bon de commande ;
- le pourcentage de factures de moins de 500 dollars (une carte de paiement peut être utilisée pour augmenter l'efficience et réduire le coût).

Les mesures de l'efficience permettent aux auditeurs de comparer un domaine d'audit à un autre à l'aide d'une description graphique des résultats. Ainsi, les graphiques A et B ci-dessous montrent que c'est la Division B qui traite le moins de transactions par utilisateur en moyenne et supporte le coût de main-d'œuvre directe le plus élevé par transaction. Il est clair que cette division aurait besoin d'améliorer son efficience opérationnelle.





L'analyse des tendances aide à détecter non seulement les problèmes, mais aussi les domaines qui ont bénéficié d'améliorations. Le graphique C montre que la Division D présente toujours le pourcentage le plus élevé de factures sans référence à un bon de commande, mais elle a réalisé des progrès considérables par rapport à l'année précédente. Le pourcentage de la Division G a, quant à lui, progressé.



Identification des déficiences de contrôles, des anomalies et des fraudes potentielles

Les anomalies possibles et les mesures de fraude potentielle sont les suivantes :

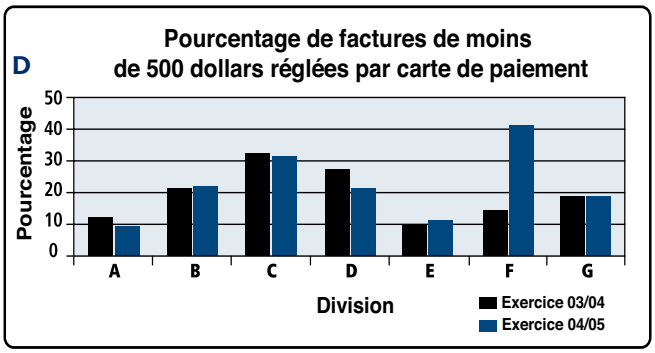
- l'identification des paiements en double (il convient d'effectuer une comparaison avec les années précédentes pour vérifier s'il y a une amélioration) ;
- les factures traitées en référence à des bons de commande créés après la date de la facture (c'est-à-dire des bons de commandes antidatés) ;
- le nombre de factures inscrites dans des comptes d'attente ;
- l'identification des doublons dans la liste des fournisseurs ou des fournisseurs portant un nom du type C.A.S.H., M., Mme, ou des fournisseurs non accompagnés de coordonnées, d'un numéro de téléphone ou d'autres informations essentielles ;
- l'identification de toutes les fonctions exécutées par chaque utilisateur afin de repérer les incompatibilités ou l'absence de séparation des fonctions, comme par exemple :
  - les fournisseurs qui n'ont été créés, et ne sont utilisés, que par un seul agent du service CF ;
  - les cas où la personne qui saisit les données est la même que celle qui autorise le paiement ;
  - les cas où le bénéficiaire est celui qui autorise le paiement.

Suivi des recommandations de l'audit

L'objectif final de l'évaluation continue du risque est le suivi des recommandations. Le but est de déterminer si le management a mis en œuvre les recommandations et si ces dernières produisent l'effet escompté. Voici quelques-unes des mesures possibles :

- preuves d'une utilisation accrue des cartes de paiement pour des transactions de faible montant (recul du pourcentage des factures de moins de 500 dollars et augmentation du pourcentage des paiements par carte pour moins de 500 dollars) ;
- réduction des doublons dans le fichier maître des fournisseurs ;
- recul du nombre et du montant des factures en double ;
- amélioration des délais de paiement (diminution des majorations pour retard de paiement, davantage d'opportunités de bénéficier de remises pour paiement à l'avance) ;
- amélioration des opérations (baisse du coût par facture, utilisation accrue des virements ou transferts électroniques de fonds) ;
- renforcement de l'accès utilisateur sur la base des rôles de chacun afin de limiter les possibilités de fraude, de gaspillage et d'abus (réduction du nombre de cas de mauvaise séparation des fonctions).

Le graphique D montre comment l'évaluation continue des risques peut servir à déterminer si les opérations CF de chaque division ont correctement mis en œuvre la recommandation préconisant l'emploi de cartes de paiement pour des transactions de faible montant.



Avec les millions de transactions qui sont saisies chaque année dans un grand nombre de centres de traitement des CF, le service d'audit peut utiliser la technologie d'audit continu avec efficacité et efficience. L'audit continu permet de définir

les objectifs d'audit, de sélectionner des sites pour les travaux d'audit sur le terrain et d'identifier les faiblesses et anomalies des contrôles. Enfin, l'audit continu permet aux auditeurs d'effectuer un suivi électronique de la mise en œuvre des recommandations de l'audit, sans avoir à se rendre sur les différents sites pour examiner des transactions manuellement.

American Institute of Certified Public Accountants (AICPA) – SAS

- SAS n° 47, Audit Risk and Materiality in Conducting Audits.
- SAS n° 54, Illegal Acts by Clients.
- SAS n° 56, Analytical Procedures.
- SAS n° 78, Amendment to SAS n° 55, Consideration of Internal Control in a Financial Statement Audit.
- SAS n° 80, Amendment to SAS n° 31, Evidential Matter.
- SAS n° 94, The Effect of Information Technology on the Auditor's Consideration of Internal Controls in a Financial Statement Audit.
- SAS n° 99, Considerations of Fraud in a Financial Statement Audit.

The Institute of Internal Auditors (IIA)

- Norme 1210 : Compétence.
- Norme 2010 : Planification.
- Norme 2120 : Management des risques.
- Norme 2130.A1
- *GTAG 1: Les contrôles des systèmes d'information.*
- *GTAG 2: Contrôles de la gestion du changement et des patchs : un facteur clé de la réussite pour toute organisation.*

Fédération internationale des comptables (IFAC) – Normes internationales d'audit (normes ISA)

- ISA 240 : « La responsabilité de l'auditeur dans la prise en considération de fraudes dans l'audit d'états financiers »

Tous les départements d'audit interne n'appliquent pas uniformément les concepts, méthodes et technologies nécessaires pour l'audit continu. Certains auditeurs savent parfaitement adopter et tirer pleinement parti de l'audit continu, tandis que d'autres n'ont même pas encore commencé à le mettre en place. La plupart des organisations se situent entre ces deux extrêmes.

Généralement, l'utilisation de l'audit continu se classe dans l'une des trois grandes catégories suivantes : élémentaire, intermédiaire, intégrée/avancée. Chaque catégorie peut se définir en fonction du niveau de mise en œuvre et d'intégration de l'audit continu dans les processus d'audit.

Le responsable de l'audit interne doit savoir où en est le service d'audit en matière d'audit continu et où il voudrait en être. Pour progresser dans l'utilisation de l'audit continu, il faut notamment évaluer les compétences et le savoir des auditeurs internes. Différents degrés de connaissances informatiques sont nécessaires au sein de l'organisation si l'on veut évaluer et améliorer l'efficience des processus de gestion, de contrôle et de gouvernance des risques. Il est essentiel de bien connaître les systèmes de l'entreprise, les risques et les contrôles y afférents, ainsi que de pouvoir utiliser l'informatique comme une ressource.

Le responsable de l'audit interne peut utiliser les descriptions suivantes pour évaluer lui-même la place de l'audit continu dans le service d'audit.

Niveau élémentaire

À ce stade, les départements d'audit n'ont pas réellement commencé à utiliser les méthodes et technologies de l'audit continu. Même si certains auditeurs tirent quelques avantages du recours à l'informatique, la plupart des tâches d'évaluation des risques et des contrôles sont toujours effectuées manuellement. À ce niveau, l'analyse des données peut servir à soutenir un audit en particulier, au coup par coup. Les analyses sont lancées une fois, et les résultats ne servent qu'à répondre à des objectifs d'audit spécifiques.

Ce stade se caractérise par les éléments suivants :

- une compréhension générale des risques et contrôles de l'entreprise ;
- l'utilisation au coup par coup de l'informatique pour rechercher des anomalies ou des exceptions ;
- des évaluations ponctuelles des transactions pour répondre à des objectifs d'un audit en particulier ;
- des évaluations des risques qui reposent sur des critères qualitatifs et manquent de quantification ;
- des évaluations des contrôles effectuées manuellement ;
- un emploi de la technologie qui n'est pas intégré au processus de planification de l'audit, de l'évaluation des risques d'audit ou de l'évaluation des contrôles.

À ce niveau, le responsable de l'audit interne ne dispose pas d'un plan lui permettant de visualiser les progrès du département d'audit dans sa mise en place de l'audit continu. La technologie informatique n'est pas planifiée, ni prise en compte dans les plans à court ou à long terme du département d'audit. L'utilisation de l'informatique se fait la plupart du temps au coup par coup et sert à régler un seul problème à la fois.

Niveau intermédiaire

Au niveau intermédiaire, les techniques d'audit continu exercent un impact sur les audits qui sont réalisés.

Cependant, cet impact reste quelque peu limité, et l'utilisation de l'audit continu n'est ni appliquée ni gérée de façon cohérente. Il arrive souvent que seuls quelques auditeurs utilisent les techniques d'audit continu, sans soutien du responsable de l'audit interne n'appuie pas leurs efforts. En outre, la direction générale de l'entreprise n'est peut-être pas au courant du type ou du périmètre de l'audit continu utilisé par ces auditeurs.

Les types d'audits effectués, les résultats obtenus et la méthode utilisée n'ont pas changé, la seule nouveauté réside dans l'utilisation de l'informatique pour exécuter certaines fonctions. Dans certains cas, l'emploi de l'informatique est planifié, mais le département d'audit n'a pas de vue d'ensemble de l'objectif ultime de l'audit continu. En outre, l'application de l'audit continu n'est pas intégrée au processus de planification de l'audit ni à l'évaluation des problèmes de risques et de contrôles.

Ce stade se caractérise par les éléments suivants :

- Une compréhension élémentaire des menaces et des vulnérabilités associées aux systèmes automatisés et aux contrôles qui y sont associés.
- Des équipes d'audit disposent des compétences et des connaissances nécessaires pour extraire et utiliser les données émanant des systèmes clés de l'entreprise.
- Un département d'audit a acheté et utilise des outils informatiques pour effectuer les évaluations et les tests.
- Des tests d'audit, servant à repérer au sein des trans actions la présence de risques et de vulnérabilités ou de déficiences des contrôles dans l'environnement informatisé, sont menés au coup par coup.
- Des symptômes qui sont reliés aux systèmes de l'entreprise afin d'identifier les causes et de formuler des recommandations.
- Les plans d'audit déployés à l'échelle de l'entreprise peuvent comporter des critères quantitatifs et quali tatifs, mais ils ne sont mis à jour qu'au moment du processus annuel de planification d'audit.

Ces départements d'audit se situent en un point critique. L'utilisation de l'audit continu risque de régresser si des individus clés quittent le département ou si l'audit continu n'est pas intégré au processus d'audit.

Niveau intégré/avancé

À ce stade, le responsable de l'audit interne et tous les auditeurs comprennent l'importance de l'informatique et de l'audit continu. Les ressources (humaines et financières) pour la mise en œuvre et la poursuite de l'utilisation de l'audit continu sont suffisantes. De plus, la technologie informatique est intégrée aux processus d'audit globaux.

L'audit est devenu un processus continu et les auditeurs évaluent les risques et les contrôles en examinant des transactions détaillées à la recherche d'anomalies ou d'exceptions et en analysant les tendances.

Les résultats servent à déclencher des alarmes, qui sont classées par ordre de priorité et donnent rapidement lieu à des mesures. À ce niveau, la nature de l'audit a changé. Les données d'entrée, de sortie et les processus ne sont pas les mêmes que ceux d'un département d'audit qui n'a pas mis en place l'audit continu.

La nature des audits, le cycle de planification, la durée du cycle et bien d'autres aspects sont affectés par la mise en place de l'audit continu.

Ce stade se caractérise par les éléments suivants :

- La connaissance des processus clés de l'entreprise et des systèmes qui y sont associés et comprennent bien les risques.
- L'identification des points de contrôle critiques, ainsi que les règles de contrôle et d'exception.
- Les principales catégories de risques et les indicateurs de risque sont fondés sur les données.
- Les évaluations des risques et des contrôles sont réalisées en temps réel ou quasi-réel pour les processus clés.
- Les systèmes clés de l'entreprise sont analysés à la recherche :
  - d'exceptions et d'anomalies au niveau des transactions,
  - de tendances indiquant des risques émergeant.
- La planification de l'audit à l'échelle de l'entreprise s'appuie sur des indicateurs de risque et de performance fondés sur les données.
- Lors des audits, on cherche activement à identifier des indicateurs issus des données pour déterminer les recommandations d'audit, indicateurs qui sont ensuite analysés afin de déterminer dans quelle mesure le management en a tenu compte.
- Les résultats de l'audit continu sont intégrés à tous les aspects du processus d'audit et sont reliés à l'ERM, aux tableaux de bord équilibrés et aux initiatives d'amélioration continue.
- Lorsqu'ils réalisent un audit continu, les auditeurs évaluent les processus de pilotage du management et en tiennent compte.
- L'audit continu est planifié, géré et évalué en vue d'une amélioration continue.

Aujourd'hui, rares sont les départements d'audit qui en sont au stade intégré/avancé. Mais il est possible d'y parvenir par une approche incrémentale, commençant par l'identification des systèmes et contrôles clés de l'entreprise. Les premières applications de l'audit continu peuvent être menées sur une base périodique, plutôt que continue. Le plus important pour les responsables de l'audit interne est de comprendre où en est le département d'audit, de réfléchir où ils aimeraient qu'il en soit et de planifier la manière d'y parvenir.

David Coderre est responsable de l'audit continu pour Sous-direction de la vérification et de l'évaluation. Fort de plus de 20 ans d'expérience en informatique dans l'environnement universitaire, dans le secteur privé et dans l'administration fédérale, il est responsable de l'utilisation efficace et efficiente des matériels et logiciels informatiques dans l'audit. Il effectue des analyses visant à étayer le périmètre et à favoriser la réalisation des objectifs de missions d'audit. Il contribue à l'élaboration du plan d'audit annuel par l'identification et l'évaluation des risques. David Coderre a mené à bien des centaines d'audits en développant, conjointement avec des équipes d'audit, des méthodes fondées sur les données pour répondre aux objectifs et au périmètre de l'audit. Lors d'un audit d'inventaire, il a notamment détecté plus de 100 millions de dollars de produits obsolètes, l'audit d'une fonction CF lui a permis de déceler près de 5 millions de dollars US d'inefficiences et plus de 1 million de dollars US de paiements en double, et, lors d'un audit de la sous-traitance de services de maintenance, il a mis en évidence des millions de dollars de transactions frauduleuses.

David Coderre est également l'auteur de *CAATTs and Other BEASTs for Auditors* (Version 3, 2005) et de *Fraud Detection: A Revealing Look at Fraud* (Version 2, 2004). Ce dernier ouvrage décrit les techniques permettant d'utiliser des logiciels d'analyse des données afin de déceler les fraudes, les gaspillages et les abus. En 2001, il a publié *The Fraud Toolkit*, qui allie logiciel et texte. Il y décrit une série de cas accompagnés de scripts spécifiquement conçus pour remédier aux fraudes. Il a également signé de nombreux articles pour des revues d'audit internationales, dont *Internal Auditor*, *The EDP Audit* et *Control and Security Newsletter* (EDPACS), the UK Journal of Auditing.

Coordonnées :
Royal Canadian Mounted Police
Audit and Evaluation Branch
295 Coventry Rd. – 2nd Floor
Ottawa, Ontario
K1A0R2, CANADA
+1-613-993-1189
Dave_Coderre@hotmail.com

Équipe du projet

Auteur principal :

David Coderre, Directeur, Audit continu, Gendarmerie royale du Canada, Ottowa, Canada

Gestionnaire du projet :

Peter Millar, Directeur, commercialisation des produits, ACL Services Ltd., Vancouver, Canada

Avec le concours de :

John G. Verver, Vice-président, Services professionnels, ACL Services Ltd., Vancouver, Canada

Experts :

John G. Verver, Vice-président, Services professionnels, ACL Services Ltd, Vancouver, Canada

J. Donald Warren Jr., Professeur de comptabilité et Directeur, Center for Continuous Auditing, Département de la comptabilité et des systèmes d'information, Rutgers University, Newark, New Jersey, États-Unis

Contributeurs :

Brian Aiken, Directeur général, Vérification et évaluation, Gendarmerie royale du Canada, Ottawa, Canada

Richard B. Lanza, Président, Cash Recovery Partners LLC, Lake Hopatcong, New Jersey, États-Unis

Sylvain Michaud, Directeur de la vérification interne, Gendarmerie royale du Canada, Ottawa, Canada

Robert, L. Onions, Directeur, Eclectics Ltd, Bude, Angleterre

Mary Persson, Directrice de la méthodologie, Gendarmerie royale du Canada, Ottawa, Canada

René-Pierre Tremblay, Directeur, Examen de la gestion et assurance de la qualité, Gendarmerie royale du Canada, Ottawa, Canada

Assurance Services Within the Auditing Profession, Glen L. Gray et Maryann, J. Gray, The IIA Research Foundation, Altamonte Springs, Floride, États-Unis, 2000.

"Beyond Traditional Audit Techniques", Paul E. Lindow et Jill D. Race, AICPA, *Online Journal of Accountancy*, juillet 2002 / Volume 194, n° 1.

Building and Implementing a Continuous Controls Monitoring and Auditing Framework – A White Paper, John G. Verver, ACL Services, 2005.

CAATTs and Other BEASTs for Auditors, David G. Coderre, Global Audit Publications, Vancouver, Canada, 1998.

COBIT, IT Governance Institute and the Information Systems Audit and Control Association.

Continuous Auditing, Instituto Canadiense de Contadores Certificados, Toronto, Canada, 1999.

"Continuous Auditing: The Audit of the Future", Zabihollah Rezaee, Rick Elanet Ahmad Sharbatoghlie, *Managerial Accounting Journal 16/3*, pp 150-158, MCB University Press.

Continuous Auditing: Implications of the Current Technological, Regulatory and Corporate Environment, J. Donald Warren Jr., Texas A&M University, mai 2004.

Continuous Auditing: Potential for Internal Auditors, J. J. Donald Warren Jr. et Xenia L. Parker, The IIA Research Foundation, Altamonte Springs, Floride, États-Unis, 2003.

Continuous Monitoring: An Effective Strategy for Effective Controls, John G. Verver, The 16th Annual Super Strategies: Audit Best-Practices Conference, MIS Training Institute, 2005.

"Detecting Accounts Payable Abuse Through Continuous Auditing", Larry Potla, *ITAudit*, The IIA, Altamonte Springs, Floride, États-Unis, Volume 6, novembre 2003.

Enterprise Risk Management: An Analytical Approach, Tillinghast-Toweres Perrin, 2000.

Enterprise Risk Management – Integrated Framework, COSO, 2004.

Financial Post, Andrew Parker, mardi 17 mai 2005.

Fraud Detection: A Revealing Look at Fraud, David G. Coderre, Ekaros, Vancouver, Canada, 2004.

The Future of Continuous Assurance and Risk Management, Tim J. Leech, Paisley Consulting, 2005.

GTAG *Information Technology Controls*, The IIA, Altamonte Springs, Floride, États-Unis, mars 2005.

Internal Auditing in Europe, ECIIA, février 2005.

Internal Control – Integrated Framework, COSO, 1992.

Professional Practices Framework, "Guidance on Implementing Auditing Standard #2", The IIA Research Foundation, Altamonte Springs, Floride, États-Unis, 2004.

Rapport de la table ronde de la conférence internationale 2005 de l'IIA, juillet 2005.

Sarbanes-Oxley Implementation Costs, A.R.C. Morgan, février 2005.

Sawyer's Internal Auditing (5th Edition): The Practice of Modern Auditing, Lawrence B. Sawyer, Mortimer A. Dittenhofer, et James H. Scheiner, Altamonte Springs, Floride, États-Unis, 2003.

SOX Compliance and Automation: A Benchmark Report, Aberdeen Group, mars 2005.

SOX Decisions for 2005: Step Up Technology Investments,John Hagerty, AMR Research, janvier 2005.

Survey on SOX 404 Implementation, Financial Executives International, mars 2005.

Technology Risk and Controls: What You Need to Know, Protiviti Independent Risk Consulting, 2004.

GTAG

Audit continu : répercussions sur l'assurance, le pilotage et l'évaluation des risques

Ce guide vise à aider les responsables de l'audit interne à comprendre comment recourir efficacement à la technologie informatique dans l'optique de l'audit continu. Il donne des orientations sur la manière d'utiliser l'audit continu afin qu'il profite à l'organisation en réduisant significativement les cas d'erreur et de fraude, en renforçant l'efficience opérationnelle et en améliorant le résultat net via la diminution des coûts, des trop-payés et du manque à gagner.

À propos des guides pratiques d'audit des technologies de l'information ?

Élaboré par l'Institute of Internal Auditors (IIA), chaque guide est rédigé dans des termes simples et traite d'un thème d'actualité qui a trait à la gestion, au contrôle et à la sécurité des SI. Cette série de guides constitue un précieux outil pour les responsables de l'audit interne, qui peuvent ainsi s'informer sur les différents risques induits par la technologie et sur les pratiques recommandées.

Guide 1: Les contrôles des systèmes d'information

Guide 2: Contrôles de la gestion du changement et des patchs : un facteur clé de la réussite pour toute organisation

Consultez le site Web de l'IIA consacré à la technologie : www.theiia.org/technology

The Institute of Internal Auditors
www.theiia.org